

EU AI Security Mapping

A practitioner's mapping of EU AI Act, NIS2, and DORA security requirements to operational controls for enterprise AI agent deployments.

Status: scaffolding. No content drafted yet.

Disclaimer: This document is a guideline based on the author's interpretation of public regulatory texts and operational security experience. It is **not legal advice**.

Table of Contents

1. [Executive Briefing](#)

2. [Scope and Disclaimer](#)

3. [Regulatory Landscape](#)

4. [Common-Control Crosswalk](#)

5. [Agent Threat Patterns and Exemplars](#)

6. [Recommended Controls and Patterns](#)

7. [Implementation Considerations](#)

8. [Gaps and Open Problems](#)

9. [References](#) - [Appendix A. ServiceNow Mapping \(Optional\)](#)

1. Executive Briefing

This section is written for security leaders and CISOs who need to make decisions about AI agent deployments under EU regulatory pressure. It is longer than a typical executive summary because the decisions are not simple. Readers wanting a two-paragraph version can read the first two paragraphs and the overview table; everything else builds on that foundation.

1.1 The bottom line

If your organization is deploying AI agents (LLM-based, tool-using systems that take multi-step actions on behalf of users), you are accepting a class of risk that your current security program does not fully address. Most enterprise security programs are built around the assumption that systems act with their own service identity and that authorization decisions are made at fixed boundaries. AI agents violate both assumptions. They act on behalf of users (so authorization must propagate through them), and they make autonomous decisions between human approval points (so the authorization boundary moves with the agent, not with the architecture).

This framework is a practitioner's view of what to do about that, mapped to the EU regulations you are now subject to or will be soon. It is not legal advice; it is operational guidance grounded in regulatory text. The framework's central claim is simple: the agent-specific layer of your security program needs five technical

controls to be defensible under EU AI Act, NIS2, DORA, and GDPR Article 22. None of the five replaces existing security infrastructure; all five extend it.

1.2 The five top exposures, in plain language

These are the patterns I see consistently in enterprise agent deployments. They are not the framework's full threat catalog (Section 5 has all ten); they are the ones a CISO will encounter first.

Top exposure	What it actually means	What addresses it (in priority order)	Effort to baseline	What regulators care about
Agent over-privilege	Your agent runs as a service account with broad rights and acts with those rights regardless of which user is asking	CTL-001 (identity propagation), CTL-003 (action verification at high-impact boundaries)	High; structural change to identity architecture	AI Act Art 14 (oversight), GDPR Art 22 (automated decisions), Art 32 (security of processing), NIS2 Art 21 (access control)
Content-as-instruction (prompt injection)	Untrusted text the agent reads (emails, web pages, documents, tool outputs) hijacks its behavior because the agent cannot reliably distinguish content from instruction	CTL-002 (provenance), CTL-003 (verification), CTL-004 (output filtering as defense-in-depth)	Medium; pattern-based, not architectural	AI Act Art 15 (cybersecurity, robustness), GDPR Art 32
Authorization confusion (the deputy problem)	Your agent acts on behalf of users incorrectly: serves data from one user to another, or acts with privileges the requesting user does not have	CTL-001 (the structural fix), CTL-004 (output filtering as defense-in-depth)	High; structural	GDPR Art 5(1)(f) (integrity, confidentiality), Art 22, Art 32
Audit incompleteness	When something goes wrong, you cannot reconstruct what the agent did, why it did it, or who is accountable	CTL-005 (end-to-end audit)	Medium; tooling investment	AI Act Art 12 (record-keeping), NIS2 Art 23 (incident reporting), DORA Art 17 (incident management), GDPR Art 5(2) (accountability)
Decision opacity	You cannot explain why the agent made a specific decision; this becomes a regulatory problem the moment a data subject contests one	CTL-002 (provenance), CTL-005 (audit)	Hard; partially solvable in current architectures	GDPR Art 22(3) (right to explanation), AI Act Art 13 (transparency to deployers)

Two clarifications worth flagging up front:

Clarification	Detail
This is curated, not exhaustive	Section 5 documents ten threat exemplars across six attack surfaces. The five exposures above are the patterns most enterprises will hit first; they are not a complete threat model
"What addresses it" lists controls in priority order	The control listed first is the structural fix; the others are defense-in-depth. Skipping the first and relying on the others is the failure mode I see most often

Where these come from: The five exposures are curated from the framework's ten threat exemplars in Section 5. The exemplars are organized by attack surface (input, model, tool-use, output, memory, audit) and tagged with MITRE ATLAS techniques where applicable. They overlap substantially with the OWASP Top 10 for LLM Applications and draw on academic work on indirect prompt injection (Greshake et al., 2023), but the structural claim of the framework, that agent threats are bounded by a finite set of attack surfaces, is the framework's own contribution. Section 5 documents the methodology for discovering deployment-specific threats that may not match the named exemplars.

1.3 What to tell your board

Three sentences that convey the situation accurately without overclaiming or underclaiming:

Audience signal	Talking point
The risk is real and measurable	"We are deploying AI agents that take actions in our systems. Our existing security controls were designed for systems that act with their own identity; agents act on behalf of users. This is a structural gap, not a tooling gap."
The regulatory pressure is concrete	"EU AI Act, NIS2, DORA, and GDPR all impose obligations that intersect with how we deploy agents. Most of these obligations are already in force; the AI Act high-risk obligations apply from August 2026. Our agent deployments are within scope of at least three of these regulations"
The work is bounded and technical	"There are five technical controls that, together, bring our agent deployments to defensible. We can build a phased plan to implement them. The work is bounded; we know what done looks like"

The corresponding things not to say to your board, because they are either not true or unhelpfully alarming:

Do not say	Why not
"AI agents are fundamentally insecure"	Not true; they are securable with specific controls. The blanket statement is the kind of claim that gets challenged and undermines the rest of the briefing
"We need to halt all AI agent deployments until we are compliant"	Almost never the right answer; staged deployment with the right controls is achievable and most regulations do not require pre-deployment certification for non-high-risk uses
"This is just like cloud security; we have done this before"	Wrong analogy; the deputy problem and content-as-instruction are genuinely new. Underclaiming undermines the case for investment

1.4 What to do, in priority order

The framework has five v1 controls (CTL-001 through CTL-005). They are not equally urgent. The priority ordering below is based on three factors: structural dependency (some controls only work if others are in place), regulatory exposure (some obligations have current enforcement, others phase in), and practical leverage (some controls produce evidence that supports compliance for multiple obligations).

Phase	Control	Why this priority	Criteria for moving to next phase
1	CTL-001 (Identity and authorization context propagation)	Structural foundation; without it, everything else either does not work or works on a weaker basis. This is also the control most enterprises fail on day one because their agents run as service accounts	Every agent action in production is associated with a verified user identity that propagates through downstream calls. Audit (CTL-005) shows this is true for at least 95% of actions over a 30-day window
2	CTL-005 (End-to-end audit and accountability)	Without audit, you cannot tell whether the other controls are working. CTL-005 also produces the evidence base for AI Act Art 12, NIS2 Art 23, DORA Art 17, GDPR Art 5(2), so its regulatory leverage is the highest of the five	Audit pipeline ingests agent events into the SIEM with sufficient detail to reconstruct any agent action. Retention period is set against the longest reporting cycle the organization is subject to (typically NIS2 Art 23 one-month cycle or DORA equivalent)
3	CTL-003 (Action verification at high-impact boundaries)	The structural mechanism for AI Act Art 14 (human oversight) and GDPR Art 22 (the human-review condition that takes a system out of "solely automated"). Cannot be effective without CTL-001 and CTL-005 in place	Approval queue is operational; thresholds are calibrated against actual operator override patterns; CTL-005 audit shows operator decisions are recorded with sufficient context for compliance
4	CTL-002 (Tool-output and context provenance)	Mitigates content-as-instruction (prompt injection). Less urgent than the first three because the worst impact of prompt injection (taking unauthorized actions) is bounded by CTL-001 and CTL-003 if those are in place	Provenance metadata is attached to content at ingest; agents distinguish content from instruction at every boundary; audit (CTL-005) shows no policy violations from injected content over a 30-day window
5	CTL-004 (Authorization-aware output filtering)	Defense-in-depth for the deputy problem and exfiltration; secondary to CTL-001 because if CTL-001 is correct, fewer cases reach CTL-004	Pre-retrieval filtering is the primary mechanism (data layer enforces per-user authorization); post-retrieval filtering is a defense-in-depth layer for content classes where pre-retrieval cannot be enforced

The criteria column matters as much as the ordering. Moving from one phase to the next without meeting the criteria is the failure mode that produces non-defensible deployments. Section 7 expands on the rollout patterns and the signals that indicate you should not move forward.

1.5 What this is going to cost

I am not going to give you a euro figure; that depends on your existing infrastructure, the scale of your agent deployment, and choices you have not yet made. I can tell you what categories of investment are involved.

Investment category	Typical magnitude	Notes
Identity infrastructure changes for CTL-001	Significant if you do not already have OAuth 2.0 token exchange or equivalent in production; modest if you do	The pattern of using a service account for the agent and re-authorizing per call is the most common starting point and the most expensive to migrate from
SIEM ingest capacity for CTL-005	Moderate; agent audit events are higher cardinality than typical application logs	Underestimating this is common; budget for substantially higher per-user log volume than equivalent non-agent applications
Approval queue tooling for CTL-003	Modest if you have existing workflow infrastructure (ServiceNow, Jira Service Management, custom workflow); higher if you are building from scratch	The expensive part is not the tooling; it is calibrating thresholds and training operators
Data layer authorization for CTL-004	Highly variable; depends on how much of your data already has per-user authorization at the data layer	If your data lives behind systems that enforce per-user authorization (most modern SaaS, well-architected internal systems), this is mostly configuration. If your data lives in shared corpora (document stores, vector indexes without per-user metadata), this is structural
Provenance tooling for CTL-002	Modest; primarily a runtime configuration and content-handling discipline	The cost here is not technical; it is operational discipline in how content enters the agent runtime

The honest framing for budget conversations: the work is bounded and largely consists of extending what you already have, not buying new categories of tooling. The exception is identity infrastructure if you do not already have user-context propagation in production; that is a real architectural investment. Everything else is incremental.

1.6 What this framework will not do for you

I want to be explicit about the limits of this document, because over-reliance on a framework like this is itself a risk.

The framework does not	What you still need
Address governance, organizational change, or culture	A separate program for AI risk governance, ethics review, and operator training
Cover detection and response controls (SIEM rules, anomaly detection on agent behavior)	Your existing SOC, augmented with agent-specific detection content; this is a v2 framework priority
Cover supply chain controls (model provenance, prompt template integrity)	Vendor risk management for your AI providers and your agent platform; this is a v2 framework priority
Cover regulatory obligations that are organizational (AI Act Art 17 QMS, Art 27 FRIA, contractual provisions under DORA Art 30)	Your compliance program; this framework is the technical layer underneath it
Constitute compliance certification	Validation by qualified counsel, your DPO, and the relevant supervisory authority before relying on this for compliance decisions

The framework's contribution is the technical agent-specific layer. It is necessary but not sufficient.

1.7 How to read the rest of this document

The remaining sections are organized for two different ways of using the framework:

If you want to	Read
Understand the regulatory landscape for agent deployments	Section 2 (scope and disclaimers), then Section 3 (regulatory landscape)
Find the right controls for a specific regulatory requirement	Section 4 (common-control crosswalk)
Understand the threat model in depth	Section 5 (threat patterns and exemplars)
Implement the v1 controls	Section 6 (control specifications) and Section 7 (implementation considerations)
Understand what the framework does not cover	Section 8 (gaps and open problems)

A practitioner deploying agents in a regulated DACH enterprise should read Section 1 (this section) and Section 7 (implementation considerations) first. The other sections become useful when specific questions arise.

A regulator or auditor evaluating an agent deployment against the framework should read Sections 2, 3, 4, 5, 6, and 8. Sections 1 and 7 are practitioner-oriented; they are not the framework's primary content for compliance evaluation.

2. Scope and Disclaimer

What this document covers

This guide addresses the security of **enterprise AI agent deployments** under EU regulatory pressure. By "agent" I mean a specific class of system, not the broader marketing category.

Attribute	In scope
Reasoning core	LLM-based
Capability	Tool-using (calls APIs, queries data sources, invokes other systems)
Execution model	Multi-step (plans and executes sequences of actions)
Autonomy	Operates autonomously between human approval points
Deployment context	Enterprise environments subject to EU AI Act, NIS2, DORA, or GDPR Article 22

The threats and controls in this document assume all five attributes hold. Systems missing one or more attributes have different threat surfaces and different control needs.

What this document does not cover

Out of scope	Why excluded
Classical RPA without an LLM reasoning core	Different threat model; established control frameworks cover it
Single-shot LLM calls (chatbots, summarization, classification) without tool use	No tool-chain attack surface; existing AI risk frameworks (NIST AI RMF, ISO 42001) cover them
Fully supervised copilots where every action requires explicit human approval	Human approval is the dominant control; agent-specific threats are bounded
Foundation model training, fine-tuning, and pre-deployment safety evaluation	Different lifecycle phase; covered by AI Act Articles 16 to 29 and AISI evaluation guidance
Consumer-facing AI products and general-purpose AI assistants	Different regulatory regime, different audience
Adversarial ML research (model extraction, membership inference, evasion)	Active research field with its own literature; orthogonal to operational deployment security
Physical-world agents (robotics, autonomous vehicles, embedded systems)	Different regulatory frameworks (Machinery Regulation, type approval)

The boundary that matters most: this document is about **operational security of agents already deployed in enterprise environments**, not the safety properties of the underlying models or agent architecture design from scratch.

Regulatory scope

The framework maps to four EU instruments:

Instrument	Relevance
EU AI Act (Regulation 2024/1689)	High-risk AI system and GPAL obligations; high-risk enforcement from August 2026
NIS2 Directive (Directive 2022/2555)	Cybersecurity obligations for essential and important entities; in force since October 2024
DORA (Regulation 2022/2554)	ICT risk management for financial entities; in force since January 2025
GDPR Article 22	Solely automated decisions with legal or similarly significant effects

Mappings to non-EU frameworks (NIST SP 800-53, ISO 27001 Annex A, BSI IT-Grundschutz) are translation aids. Verified citations and dates are maintained in `../frameworks/regulatory-facts.md`, from which Section 3 draws.

Threat catalog scope

The 10 threats in Section 5 are **exemplars within an attack surface taxonomy**, not an exhaustive enumeration. Coverage of all 10 does not mean coverage of all agent threats. Section 5 documents the methodology for discovering threats specific to a deployment; the methodology is the durable contribution, not the catalog.

Control library scope

The 5 controls in Section 6 are a **coarse-grained v1**. Detection and response (SIEM integration, behavioral anomaly detection), supply-chain controls (model provenance, prompt-template integrity), and human-factors controls (operator training, alert-fatigue management) are acknowledged gaps in Section 8 and are v2 priorities. Honest gap acknowledgment beats false comprehensiveness; the library will expand in v2 based on customer engagement feedback.

Disclaimer and author affiliation

I am a Senior Staff Information Security Analyst in the Office of the CISO at ServiceNow, based in Munich. This framework is independent practitioner work. It is vendor-neutral and product-agnostic.

Specifically:

Statement	Meaning
The framework names no vendor products in threat descriptions, control specifications, or mappings	The body of the work is product-agnostic by construction
Vendor-specific mappings are accepted as community contributions through a defined schema and process (see Vendor Mapping Framework)	The author does not produce vendor mappings as part of the core framework
The author recuses from reviewing ServiceNow submissions to the vendor mapping interface	A separate reviewer chain handles ServiceNow contributions to avoid conflict of interest
Nothing in this document constitutes legal advice, certification of compliance, or regulatory interpretation binding on any authority	This is practitioner guidance; binding interpretation comes from regulators, courts, and qualified counsel
Views expressed are the author's own and do not represent ServiceNow's official positions, product commitments, or regulatory interpretations	Standard separation between employer and independent practitioner work

Readers using this framework in regulated contexts should validate findings with qualified counsel, their data protection officer, and the relevant supervisory authority before relying on it for compliance decisions.

3. Regulatory Landscape

Four EU instruments shape the security obligations of an enterprise AI agent deployment in the DACH region: the EU AI Act, the NIS2 Directive, DORA, and GDPR (specifically Article 22). They were drafted independently, on different timelines, and with different primary objectives. They overlap on operational security in ways that are not always obvious from the text. This section walks each instrument in turn at the depth a security practitioner needs to identify which articles apply to a given deployment and what they require operationally. Detailed control mappings are deferred to Sections 4 and 6; threat-level analysis to Section 5.

Verified citations, dates, and article numbers throughout this section are drawn from [../frameworks/regulatory-facts.md](#). Where legal interpretation is contested, I flag it; where the text is settled, I do not over-qualify.

EU AI Act (Regulation (EU) 2024/1689)

The AI Act is the only one of the four instruments written specifically for AI systems. It was adopted on 13 June 2024, published in the Official Journal on 12 July 2024, and entered into force on 1 August 2024. Its substantive obligations apply on a staggered schedule.

Application date	Provisions
2 February 2025	Prohibitions in Chapter II (e.g. social scoring, untargeted facial recognition scraping) and AI literacy obligations
2 August 2025	Governance provisions and obligations on general-purpose AI (GPAI) model providers (Chapter V)
2 August 2026	Most remaining provisions, including the Annex III high-risk obligations that affect typical enterprise agent deployments
2 August 2027	Article 6(1) high-risk systems (AI as safety components in products under Annex I sectoral law: medical devices, civil aviation, etc.)

The Commission published a Digital Omnibus simplification proposal on 19 November 2025 that may extend the high-risk application timeline by up to 16 months pending availability of harmonised standards. This is a moving target; verify before relying on a specific date for compliance planning.

For agent security, the relevant articles cluster around risk management, data governance, oversight, and operational security:

Article	Topic	Why it matters for agent security
Article 6 and Annex III	High-risk classification rules	Determines whether the deployment is high-risk and which obligations apply
Article 9	Risk management system	Direct hook for threat modeling and control selection
Article 10	Data and data governance	Training-data quality, bias mitigation, representativeness for high-risk systems
Article 12	Record-keeping (logging)	Direct hook for audit and provenance controls (see CTL-005 in Section 6)
Article 13	Transparency and information to deployers	Informs customer-facing security advisories
Article 14	Human oversight	Direct hook for action-verification and approval-boundary controls (see CTL-003)
Article 15	Accuracy, robustness, cybersecurity	The single most operationally relevant article; cited against most threats in Section 5
Articles 16 to 22	Provider obligations (QMS, technical documentation, automatically generated logs, corrective action, cooperation, authorised representatives)	Apply if the customer is the AI system provider
Article 26	Deployer obligations for high-risk AI systems	Apply to most enterprise customers running purchased agents
Article 27	Fundamental rights impact assessment	Required of public-sector deployers and certain private deployers
Article 50	Transparency obligations for AI systems interacting with natural persons	Disclosure that the user is interacting with AI
Articles 53 to 55	GPAI model provider obligations	Apply to model providers (OpenAI, Anthropic, Google, Mistral, Meta, etc.), not deployers

The provider/deployer distinction matters operationally. A typical enterprise customer is a deployer of a purchased agent platform. Deployer obligations under Article 26 (use in line with provider instructions, monitoring, logging, human oversight, incident reporting) are the obligations that drive day-to-day operational security. Provider obligations under Articles 16 to 22 apply to the platform vendor; in practice, the customer inherits security properties from how well the provider implements them. If the customer builds the agent in-house on top of a foundation model, both sets of obligations may apply simultaneously.

What this means for agent deployments: The AI Act gives the framework its primary anchor. Article 9 (risk management) and Article 15 (cybersecurity, robustness, accuracy) are cited across the threat catalog in Section 5 because they make AI-specific operational security legally binding for the first time. Article 12 (logging) is the legal hook for audit controls that already exist as good engineering practice. Article 14 (human oversight) constrains how much autonomy an agent can have between approval points without violating the Act, which directly shapes the high-impact-action verification controls in Section 6. The August

2026 application date for Annex III obligations is the binding deadline for most enterprise deployments. The Article 6(1) date in August 2027 matters only for AI embedded as safety components in products covered by sectoral law (medical devices, civil aviation, automotive, etc.).

NIS2 Directive (Directive (EU) 2022/2555)

NIS2 is the second-generation EU cybersecurity directive. It was adopted on 14 December 2022, entered into force on 16 January 2023, and member states were required to transpose it into national law by 17 October 2024. National measures became applicable from 18 October 2024 in member states that transposed on time. The original NIS Directive (Directive 2016/1148) was repealed on 18 October 2024.

NIS2 expanded the scope of the original directive substantially:

Dimension	NIS1	NIS2
Sectors in scope	7	18 (Annex I plus Annex II)
Estimated entities in scope	10,000 to 15,000 across the EU	Approximately 160,000 (ENISA)
Entity classification	Operators of essential services / digital service providers	Essential entities / important entities

The expansion catches enterprises that were previously out of NIS scope, including many that operate AI agents. Cloud computing service providers, data centre service providers, ICT service management (B2B), digital providers, and managed security services are explicitly named. Many DACH enterprises that did not previously identify as critical infrastructure now sit inside the directive's scope.

Three articles dominate the operational security analysis:

Article	Topic
Article 21	Cybersecurity risk-management measures: a 10-point list including risk analysis, incident handling, business continuity, supply chain security, vulnerability disclosure, basic cyber hygiene, encryption, access control, MFA, and security in network and information systems acquisition, development and maintenance
Article 23	Reporting obligations: 24-hour early warning, 72-hour incident notification, one-month final report
Article 32	Supervisory measures and penalties

Article 21 is intentionally broad. It does not specify how to implement each measure; member states and competent authorities flesh that out through national law and guidance. This means Article 21 reads like a minimum expectation rather than a prescriptive control catalog. For agent security, the substantive content is in supply-chain security (Article 21(2)(d)), incident handling (Article 21(2)(b)), access control and MFA (Article 21(2)(i) and (j)), and encryption (Article 21(2)(h)).

DACH transposition status

Transposition is uneven. As of early 2026:

Country	Status	Note
Germany	Transposed	NIS2UmsuCG (NIS-2-Umsetzungs- und Cybersicherheitsstärkungsgesetz) approved by Bundestag on 13 November 2025 and entered into force on 6 December 2025; the BSI Act now covers approximately 29,500 supervised entities (up from approximately 4,500); BSI portal registration window opens 6 January 2026; no transition period
Austria	Not yet transposed	First draft (NISG 2024) rejected by the National Council in February 2024; revised draft NISG 2026 published 13 November 2025; entry into force scheduled 1 October 2026; until then NISG 2018 applies
Switzerland	Out of scope	Not an EU member; relevant only to Swiss entities providing services into the EU

For German entities, the implementing law is now in force; the relevant operational reference is the revised BSI Act (BSIG) rather than the directive text alone. Verify the current state and any sector-specific implementing rules with qualified counsel before relying on this section for compliance decisions.

What this means for agent deployments: NIS2 supplies the general cybersecurity baseline that AI agents inherit by virtue of running inside an in-scope enterprise. It is not AI-specific. Article 21's 10-point list maps cleanly onto traditional security controls; the agent-specific overlay (prompt injection, authorization confusion, tool-chain abuse, etc.) sits on top of that baseline rather than replacing it. The supply-chain security obligation (Article 21(2)(d)) is the most relevant for agent deployments because it pulls foundation model providers, agent platform vendors, and tool integrations into the scope of the customer's NIS2 risk assessment. Incident reporting timelines under Article 23 are tight; agent-specific incidents (prompt-injection-driven exfiltration, authorization-confusion-driven actions) can trigger them just like traditional incidents.

DORA (Regulation (EU) 2022/2554)

DORA is the EU's digital operational resilience regulation for the financial sector. It was adopted on 14 December 2022 (the same day as NIS2), entered into force on 16 January 2023, and applies from 17 January 2025. A companion directive (Directive (EU) 2022/2556) had a transposition deadline of 17 January 2025. Unlike NIS2, DORA is a regulation, so it applies directly without national transposition.

DORA is structured around five pillars:

Pillar	Articles
ICT risk management	Articles 5 to 16
ICT-related incident management, classification, reporting	Articles 17 to 23
Digital operational resilience testing	Articles 24 to 27
ICT third-party risk management	Articles 28 to 30
Information and intelligence sharing	Article 45

For agent security in financial entities, the high-leverage articles are:

Article	Topic
Article 6	ICT risk management framework (the umbrella requirement)
Article 9	Protection and prevention (security controls baseline)
Articles 17 and 18	ICT incident classification and major-incident reporting
Article 28	General principles for ICT third-party risk
Article 30	Mandatory contractual provisions for ICT services supporting critical or important functions

The third-party risk pillar deserves particular attention for agent deployments. Article 30 specifies contractual provisions that financial entities must include in agreements with ICT service providers supporting critical or important functions: rights to audit, exit strategies, security and incident notification obligations, sub-contracting restrictions, and assistance during incidents. Foundation model providers, agent platform vendors, and major tool integrations sit inside this scope when an agent supports a critical or important function.

The Commission designated the first 19 critical ICT third-party providers (CTPPs) on 18 November 2025, including AWS, Microsoft, Google Cloud, IBM, Bloomberg, LSEG, TCS, and Orange. CTPP designation triggers direct EU oversight under Articles 31 to 44, including the right of EU lead overseers to conduct on-site inspections at the provider. Foundation model providers are not currently on the list; that does not mean they cannot be added in subsequent rounds.

What this means for agent deployments: For financial entities, DORA's third-party risk obligations make the foundation model provider, the agent platform vendor, and major tool integrations into named, contractually constrained, regulator-visible elements of the deployment. This is the most operationally specific of the four instruments for agents in financial services. Articles 17 and 18 incident reporting overlap with NIS2 Article 23 reporting; the entity-specific question is which regulator gets the report first and whether a single submission discharges both obligations (this is jurisdiction-specific; verify with national authorities). Article 9's protection and prevention requirements map onto the same operational controls as the AI Act's Article 15 cybersecurity obligation, with finance-specific accent on resilience and continuity.

GDPR Article 22 (Regulation (EU) 2016/679)

GDPR has applied since 25 May 2018. Most of its provisions are well-traveled by now. For agent security specifically, Article 22 is the article that matters and the only one I cover here in any depth.

Article 22(1) states:

"The data subject shall have the right not to be subject to a decision based solely on automated processing, including profiling, which produces legal effects concerning him or her or similarly significantly affects him or her."

Article 22(2) specifies the conditions under which a solely automated decision is permitted:

Basis	Reference
Necessary for entering into or performance of a contract between data subject and controller	Article 22(2)(a)
Authorised by Union or Member State law with suitable safeguards	Article 22(2)(b)
Based on the data subject's explicit consent	Article 22(2)(c)

In cases (a) and (c), Article 22(3) requires the controller to implement suitable measures to safeguard the data subject's rights, at minimum: the right to obtain human intervention, to express their point of view, and to contest the decision.

The operationally critical word in Article 22(1) is "solely". An automated decision is in scope only if no meaningful human review takes place. The threshold for "meaningful" review is set by EDPB Guidelines on Automated Decision-Making (WP251rev.01): the human reviewer must have the authority and competence to override the decision. Rubber-stamp human approval that always confirms the algorithmic recommendation does not qualify. A reviewer who lacks the data, expertise, or organizational authority to disagree does not qualify either.

This is exactly where agentic AI creates new risk. An agent that "recommends" an action that is then "approved" by a human one-click reviewer is, in practice, making a solely automated decision dressed up as a human one. The Article 22 risk is not theoretical; supervisory authorities have shown willingness to look through the form to the substance.

What this means for agent deployments: Article 22 is the legal lever for the human-oversight design pattern that runs through Section 6 (specifically CTL-003: Action Verification at High-Impact Boundaries). The framework's position is that high-impact actions (financial transactions, hiring or termination, credit or lending, access to services with legal effects) require human approval that is meaningful, not nominal. The control library specifies what meaningful means operationally: independent context, override authority, sufficient time, and audit of overrides. Article 22 also limits how aggressive an agent can be in autonomy progression: every increment in autonomy reduces the share of decisions that get meaningful human review, and at some point the system crosses into "solely automated" territory. The crossing is not always obvious; it deserves explicit design and legal review.

DACH-specific national rules

Two German national rules deserve mention because they intersect with agent deployments in specific sectors.

BSI C5 Equivalence Regulation (C5-Gleichwertigkeitsverordnung, C5GleichwV)

The C5 Equivalence Regulation was published on 19 March 2025 (BGBl. 2025 I Nr. 91) with retroactive effect from 1 July 2024. Its statutory basis is § 393 Abs. 4 Satz 4 SGB V, introduced by the DigiG (22 March 2024). Scope: cloud computing services processing social or health data for healthcare providers, statutory health insurers, and their processors. Mechanism: it permits alternative certifications (ISO 27001 auf Basis IT-Grundschutz, SOC 2) as temporarily equivalent to a C5-Type-1 testat, for a maximum of two years, conditional on a documented gap-closure plan toward C5-Type-2. Relevance to agent security is narrow: it affects healthcare-sector cloud and AI deployments in Germany specifically.

BSI IT-Grundschutz

IT-Grundschutz is the German national security baseline framework, maintained by the Bundesamt für Sicherheit in der Informationstechnik (BSI). Its annual IT-Grundschutz-Kompendium serves as a national reference catalog of building blocks (Bausteine), threats (Gefährdungen), and security requirements. The framework treats it as a translation aid alongside NIST SP 800-53 and ISO 27001 Annex A, not as a primary regulatory anchor.

What this means for agent deployments: The DACH-specific rules narrow the framework's relevance for two specific cases (German healthcare cloud; mappings to a German national baseline) without changing the primary EU-level analysis. Practitioners working in those contexts should treat the DACH section as a hook into more specialized guidance from BSI and the national supervisory authorities; it is not a substitute for that guidance.

How the four instruments interact

The four instruments are layered, not parallel:

Layer	Instrument	What it adds
AI-specific	EU AI Act	Risk classification, AI-specific obligations on data, oversight, accuracy, robustness, cybersecurity
Sectoral cybersecurity	NIS2	Cybersecurity baseline for in-scope entities; supply chain and incident reporting
Sectoral cybersecurity (financial)	DORA	Operational resilience for financial entities; ICT third-party risk; CTPP regime
Data protection	GDPR Article 22	Human oversight requirement for solely automated decisions affecting individuals

A given deployment can sit inside two, three, or all four scopes simultaneously. A high-risk AI agent deployed by a German bank to make credit decisions on retail customers triggers all four: AI Act (high-risk classification under Annex III), NIS2 (banking is a NIS2 essential entity sector), DORA (banks are explicitly in scope), and GDPR Article 22 (credit decisions are solely automated decisions with legal or similarly significant effects). The framework's Section 4 maps where the four instruments converge on common controls, which is what makes integrated compliance tractable rather than four parallel projects.

The more general point: a security practitioner who understands the agent-specific threat model in Section 5 and applies the controls in Section 6 will satisfy a substantial portion of the operational obligations across all four instruments. The remainder is process, documentation, and governance work outside the operational security scope of this framework.

4. Common-Control Crosswalk

How to read this section

This section maps regulatory requirements to the controls in this framework's v1 control library (CTL-001 through CTL-005). It is a navigation aid, not a compliance certification. A cell that names a control means the control contributes substantively to satisfying the requirement; it does not mean the control alone

discharges the obligation. Most regulatory requirements are satisfied by a combination of controls, organizational measures, and operational evidence that fall outside the technical scope of this framework.

The mappings below connect requirements to controls through the bridging threat that puts the requirement at risk. The bracketed [via AGT-NNN] notation cites the threat. This reflects how `../data/mappings.json` actually models the relationship: a regulatory requirement does not connect to a control directly; the connection runs through a specific agent threat that the control mitigates and that the requirement either explicitly or implicitly addresses. The bridging-threat notation makes the evidence chain visible.

The primary view is requirement-to-control. A summary table at the end (subsection 4.6) presents the inverse view for readers navigating from the control library.

Honest gaps in the v1 crosswalk are documented in subsection 4.7.

EU AI Act: requirements and matching controls

AI Act requirement	Bridging threats	v1 controls (with bridge)
Article 9 (Risk management system)	AGT-001, AGT-003, AGT-009	CTL-001 [via AGT-001, AGT-003], CTL-002 [via AGT-001, AGT-009], CTL-003 [via AGT-001, AGT-003, AGT-009], CTL-005 [via AGT-001, AGT-003, AGT-009]
Article 10 (Data and data governance)	AGT-006	None in v1 (this is primarily a provider-side training-data obligation; v1 controls do not address training data quality. Memory poisoning under AGT-006 is the closest agent-deployment connection)
Article 12 (Record-keeping)	AGT-005	CTL-005 [via AGT-005, primary], CTL-001 [via AGT-005, primary], CTL-002 [via AGT-005, primary]
Article 13 (Transparency to deployers)	AGT-005	CTL-001 [via AGT-005], CTL-002 [via AGT-005], CTL-005 [via AGT-005]
Article 14 (Human oversight)	AGT-001, AGT-002, AGT-003, AGT-005, AGT-007, AGT-009	CTL-003 [via AGT-001, AGT-002, AGT-003, AGT-007, AGT-009; primary across most], CTL-002 [via AGT-005, AGT-007, AGT-009], CTL-005 [via AGT-005, AGT-009]
Article 15 (Accuracy, robustness, cybersecurity)	AGT-001, AGT-002, AGT-004, AGT-006, AGT-007, AGT-008, AGT-009, AGT-010	CTL-001 [via most], CTL-002 [via AGT-001, AGT-006, AGT-007, AGT-008, AGT-009], CTL-003 [via most], CTL-004 [via AGT-002, AGT-004, AGT-008], CTL-005 [via most] (all five v1 controls contribute; cybersecurity is addressed by the entire library)

What this means for agent deployments: The v1 control library covers the technical core of AI Act compliance for agent deployments, with strongest coverage of Articles 12 (logging), 14 (oversight), and 15 (cybersecurity). Coverage of data governance (Article 10) and process obligations (QMS, FRIA) is intentionally out of scope. Deployers should treat this framework as the technical layer of a broader compliance program, not as the program itself.

NIS2: requirements and matching controls

NIS2 mappings in `mappings.json` reference Article 21 at the article level rather than the sub-paragraph level. The crosswalk preserves that granularity.

NIS2 requirement	Bridging threats	v1 controls (with bridge)
Article 21 (Cybersecurity risk-management measures, general)	AGT-001, AGT-002, AGT-004, AGT-005, AGT-006, AGT-007, AGT-008, AGT-010	CTL-001 [via most], CTL-002 [via AGT-001, AGT-005, AGT-006, AGT-007, AGT-008], CTL-003 [via most], CTL-004 [via AGT-002, AGT-004, AGT-008], CTL-005 [via most] (NIS2 Art 21 is the universal cybersecurity baseline; the full v1 library contributes through the threats it mitigates)

What this means for agent deployments: NIS2 Article 21 sets the cybersecurity risk-management baseline. The v1 controls address the agent-specific layer that sits on top of foundational cybersecurity baselines (cryptography, MFA, backup, network segmentation, supply chain). Entities subject to NIS2 should treat this framework as agent-specific reinforcement of an existing NIS2 program, not as a substitute for it. Sub-paragraph-level coverage of Article 21 (for example, 21(2)(a) policies, 21(2)(d) supply chain, 21(2)(g) hygiene and training) is documented in subsection 4.7.

DORA: requirements and matching controls

DORA requirement	Bridging threats	v1 controls (with bridge)
Articles 6 to 8 (ICT risk-management framework)	AGT-001, AGT-002, AGT-003, AGT-004, AGT-008, AGT-010	CTL-001 [via most], CTL-002 [via AGT-001, AGT-008], CTL-003 [via AGT-001, AGT-002, AGT-003, AGT-008], CTL-004 [via AGT-002, AGT-004, AGT-008], CTL-005 [via most] (the v1 controls form the technical agent-specific layer of the ICT risk management framework)
Article 9 (Identification and classification of ICT-supported business functions)	AGT-002	CTL-001 [via AGT-002, primary], CTL-003 [via AGT-002, primary], CTL-004 [via AGT-002, primary], CTL-005 [via AGT-002]
Article 12 (Major ICT-related incidents)	AGT-005	CTL-005 [via AGT-005, primary], CTL-001 [via AGT-005, primary], CTL-002 [via AGT-005, primary]
Articles 28 to 30 (ICT third-party risk)	AGT-007	CTL-001 [via AGT-007, primary], CTL-002 [via AGT-007, primary], CTL-003 [via AGT-007, primary], CTL-005 [via AGT-007] (third-party risk applies when sub-agents integrate third-party services; contractual provisions under Article 30 are organizational and not addressed by v1 technical controls)

What this means for agent deployments: DORA's five-pillar structure means the v1 controls primarily address Pillar 1 (ICT risk management) and parts of Pillar 4 (third-party risk via sub-agent delegation). Pillars 2 (incident reporting), 3 (resilience testing), and 5 (information sharing) are largely organizational. Financial entities deploying agents should treat this framework as the technical agent-specific component of Pillars 1 and 4, integrated into the broader DORA programme.

GDPR: requirements and matching controls

GDPR coverage extends beyond Article 22. The crosswalk includes the GDPR articles named in `mappings.json` because all of them are directly relevant to enterprise agent deployments.

GDPR requirement	Bridging threats	v1 controls (with bridge)
Article 5(1)(b) (Purpose limitation)	AGT-009	CTL-002 [via AGT-009], CTL-003 [via AGT-009], CTL-005 [via AGT-009]
Article 5(1)(c) (Data minimization)	AGT-003, AGT-009	CTL-001 [via AGT-003], CTL-003 [via AGT-003, AGT-009], CTL-005 [via AGT-003, AGT-009]
Article 5(1)(d) (Accuracy)	AGT-006	CTL-002 [via AGT-006, primary], CTL-003 [via AGT-006], CTL-005 [via AGT-006]
Article 5(1)(f) (Integrity and confidentiality)	AGT-002, AGT-004	CTL-001 [via AGT-002, AGT-004; primary], CTL-003 [via AGT-002], CTL-004 [via AGT-002, AGT-004; primary], CTL-005 [via AGT-002, AGT-004]
Article 5(2) (Accountability)	AGT-005, AGT-007	CTL-001 [via AGT-005, AGT-007], CTL-002 [via AGT-005, AGT-007], CTL-005 [via AGT-005, primary; AGT-007]
Article 17 (Right to erasure)	AGT-006	CTL-002 [via AGT-006, primary], CTL-005 [via AGT-006] (erasure is more complex when persisted state has influenced agent behavior; provenance and audit are necessary but not sufficient)
Article 22 (Automated individual decision-making)	AGT-001, AGT-002, AGT-005	CTL-001 [via AGT-002], CTL-003 [via AGT-001, AGT-002; the structural mechanism for ensuring decisions are not "solely" automated], CTL-004 [via AGT-002], CTL-005 [via AGT-005; supports the right-to-explanation by providing auditable decision provenance]
Article 25 (Data protection by design and by default)	AGT-002, AGT-003, AGT-009	CTL-001 [via AGT-002, AGT-003], CTL-003 [via AGT-003, AGT-009], CTL-005 [via AGT-009]
Article 32 (Security of processing)	AGT-001, AGT-002, AGT-004, AGT-008	CTL-001 [via AGT-002, AGT-004; primary], CTL-002 [via AGT-001, AGT-008], CTL-003 [via AGT-001, AGT-002, AGT-008], CTL-004 [via AGT-002, AGT-004, AGT-008; primary]

What this means for agent deployments: GDPR coverage in the v1 controls is broader than Article 22 alone. Article 32 (security of processing) is satisfied substantively by CTL-001, CTL-003, and CTL-004 across multiple threats. Article 5(1)(f) (integrity and confidentiality) is the principle-level anchor for the deputy and exfiltration patterns. Article 22 specifically applies only when the agent makes solely automated decisions producing legal or similarly significant effects on individuals; CTL-003 is the structural mechanism for placing meaningful human review at the decision boundary. Where Article 22 applies, deployers should pair CTL-003 with the organizational measures (lawful basis assessment, data subject communication, contestability process) that the v1 control library does not address.

Common-control summary: control-to-requirement view

This subsection presents the inverse of the requirement-to-control crosswalk. For each v1 control, the table indicates which regulatory requirements it contributes to (across all bridging threats). This view is intended for readers navigating from the control library rather than from a regulatory question.

Control	EU AI Act	NIS2	DORA	GDPR
CTL-001 (Identity and authorization context propagation)	Articles 9, 12, 13, 14, 15	Article 21	Articles 6 to 8, 9, 12, 28 to 30	Articles 5(1)(c), 5(1)(f), 5(2), 22, 25, 32
CTL-002 (Tool-output and context provenance)	Articles 9, 12, 13, 14, 15	Article 21	Articles 6 to 8, 12, 28 to 30	Articles 5(1)(b), 5(1)(d), 5(2), 17, 32
CTL-003 (Action verification at high-impact boundaries)	Articles 9, 14, 15	Article 21	Articles 6 to 8, 9, 28 to 30	Articles 5(1)(b), 5(1)(c), 5(1)(d), 5(1)(f), 22, 25, 32
CTL-004 (Authorization-aware output filtering)	Article 15	Article 21	Articles 6 to 8, 9	Articles 5(1)(f), 22, 32
CTL-005 (End-to-end audit and accountability)	Articles 9, 12, 13, 14, 15	Article 21	Articles 6 to 8, 9, 12, 28 to 30	Articles 5(1)(b), 5(1)(c), 5(1)(d), 5(1)(f), 5(2), 17, 22, 25

The pattern: CTL-005 carries the broadest regulatory weight because logging, audit, and accountability are universal requirements across all four instruments. CTL-001 and CTL-003 are the structural anchors for human-oversight and access-control requirements. CTL-002 is the specialized control for provenance-related obligations (transparency, accuracy, erasure). CTL-004 has the narrowest direct mapping but is decisive for confidentiality and Article 22 contexts.

Honest gaps in the crosswalk

Several requirements in the four instruments have no direct match in the v1 control library because no v1 threat bridges them to a v1 control. These gaps are intentional; v1 is scoped to the agent-specific operational security layer, not to the foundational cybersecurity baseline or the organizational compliance program.

Requirement	Why no v1 match	Where it belongs
AI Act Article 10 (training-data governance)	Provider-side obligation focused on training data; AGT-006 (memory poisoning) is the closest agent-deployment bridge but does not satisfy the full obligation	Outside v1 scope; AI Act provider compliance frameworks
AI Act Article 16 (provider obligations, general); Article 17 (QMS); Article 19 (provider log retention); Article 26 (deployer obligations); Article 27 (FRIA)	Process and organizational obligations; v1 controls provide the technical substrate (especially CTL-005 for logging) but the obligations themselves are not satisfied by technical controls alone	Outside v1 scope; covered by AI Act compliance program guidance
NIS2 Article 21(2)(c) (business continuity, backup, crisis management)	Foundational ICT continuity controls	Assumed to exist independently; ISO 22301, NIST SP 800-34
NIS2 Article 21(2)(d) (supply chain security)	Out of scope per Section 8	Flagged for v2 expansion
NIS2 Article 21(2)(e) (secure development, vulnerability handling)	SDLC controls outside v1 scope; CTL-002 (provenance) contributes partially	Outside v1 scope; covered by SSDLC frameworks
NIS2 Article 21(2)(g) (cyber hygiene, training)	Human factors out of scope per Section 8	Flagged for v2 expansion
NIS2 Article 21(2)(h) (cryptography and encryption)	Foundational control assumed	NIST SP 800-53, BSI IT-Grundschutz
NIS2 Article 21(2)(i, j) (HR security, access control, MFA)	Foundational identity and access controls; CTL-001 depends on these being in place	Assumed to exist; identity provider frameworks
NIS2 Article 23 (incident reporting)	Reporting process is organizational; CTL-005 provides the underlying audit data	Outside v1 scope; covered by SOC and incident response frameworks
DORA Article 10 (detection)	First-class detection controls out of scope per Section 8	Flagged for v2 expansion
DORA Article 11 (response and recovery); Article 12 (backup)	Foundational ICT continuity	Assumed to exist; ISO 22301
DORA Article 17 to 18 (incident classification and reporting)	Reporting and classification process is organizational	Outside v1 scope
DORA Article 30 (mandatory contractual provisions)	Contractual, not technical	Outside v1 scope
GDPR Articles 13(2)(f), 14(2)(g), 15(1)(h) (transparency about automated decision-making logic)	Data subject communication is organizational; CTL-002 (provenance) contributes the logic substrate	Outside v1 scope; covered by privacy notice and data subject request processes

For the gaps flagged as v2 expansion priorities (detection, supply chain, human factors), see Section 8. For the gaps that are intentional foundations of an existing security program, this framework assumes the foundations are in place and addresses only the agent-specific layer that sits on top.

5. Agent Threat Patterns and Exemplars

This section presents the framework's view of agent-specific threats. It is structured in three layers, each playing a distinct role.

The first layer is an attack surface taxonomy. Agents have a bounded set of attack surfaces (input, model, tool-use, output, memory and persistence, audit and provenance), and each surface produces recognizable threat patterns. The taxonomy is the durable structural claim of the framework: it is finite, derived from the architectural components every agent has, and stable across deployments.

The second layer is a set of ten named threat exemplars (AGT-001 through AGT-010), one or two illustrative threats per attack surface. Each exemplar is documented with an attack scenario, an analysis of why traditional controls are insufficient, recommended controls from the v1 library, residual risk, detection and mitigation maturity, regulatory hooks, and MITRE ATLAS mappings. The exemplars are not an exhaustive enumeration of agent threats. They illustrate patterns concretely enough that practitioners can recognize variants in their own deployments.

The third layer is methodology for discovering threats specific to a deployment that may not match the named exemplars. The methodology is essential: threats are infinite, no catalog can be complete, and the framework's value lies in the taxonomy and the structured way of thinking, not in the specific list of named threats. The methodology is documented in `docs/frameworks/THREAT_MODEL_FRAMEWORK.md`; this section references it rather than restating it.

Provenance of the threat catalog

The framework's threat catalog draws on multiple sources, each playing a different role:

Source	Role in the catalog
Attack surface taxonomy (input, model, tool-use, output, memory, audit)	Framework-original. The structural claim that agent threats are bounded by a finite set of architectural surfaces is the framework's primary contribution and is not adopted from any specific external catalog
MITRE ATLAS (Adversarial Threat Landscape for Artificial-Intelligence Systems)	Secondary tagging on each exemplar where applicable. ATLAS provides technique-level adversarial-ML reference; this framework uses ATLAS technique IDs as cross-references but does not adopt ATLAS taxonomy as the primary structure
OWASP Top 10 for LLM Applications	Substantial overlap with several exemplars (notably AGT-001 prompt injection, AGT-004 data exfiltration). OWASP Top 10 is the most widely-recognized agent-relevant catalog among practitioners; the framework's exemplars overlap intentionally to ease cross-referencing, but the catalog is not derived from OWASP
Greshake et al., "Not What You've Signed Up For: Compromising Real-World LLM-Integrated Applications with Indirect Prompt Injection," AISeC '23	Specific influence on AGT-001 (prompt injection via tool outputs). Cited in the exemplar as the canonical academic reference for the indirect-injection pattern
Author's practitioner experience in DACH regulated enterprises	The curation choice: which threats made the cut as exemplars, which residual risks were highlighted, and which regulatory hooks were emphasized. This influence is unavoidable in any practitioner framework and is acknowledged here rather than disguised
Cross-references to MITRE ATT&CK and NIST AI 100-2 (Adversarial Machine Learning)	Applied where threats overlap with general adversarial-ML or general-IT-security patterns; cited in individual exemplars rather than as primary structure

The framework's claim is not that these ten threats are the complete or correct set; it is that the attack surface taxonomy is bounded and that the methodology for discovering deployment-specific threats is the durable contribution. Practitioners using this section should not interpret coverage of the ten exemplars as completion of agent threat work. Coverage of the exemplars is necessary but not sufficient. The actual security work is in applying the taxonomy and methodology to the specific deployment, complemented by external catalogs (MITRE ATLAS, OWASP LLM Top 10, MITRE ATT&CK, NIST AI 100-2) for technique-level detail.

Note on v1 scope: The canonical document at v1 contains the framing above; the exemplar bodies are not inlined here. AGT-001 (Prompt injection via tool outputs) and AGT-002 (Authorization confusion) are fully populated in `docs/sections/05-threat-model.md`, with attack scenario, traditional controls and why insufficient, recommended controls, residual risk, detection and mitigation maturity, regulatory hooks, and MITRE ATLAS mappings. AGT-003 through AGT-010 are present as compressed exemplars in the same section file and in `data/threats.json`: they cover attack scenario, recommended controls, and regulatory hooks but defer realistic deployment examples and full residual-risk analysis. Practitioners requiring depth equivalent to AGT-001 and AGT-002 should treat AGT-003 through AGT-010 as patterns to recognize rather than fully-documented exemplars at v1. Section 8 records the v1.1 commitments to populate AGT-003 through AGT-010 to parity and to merge full exemplar bodies into the canonical document.

6. Recommended Controls and Patterns

This section presents a coarse-grained v1 control library of 10 to 15 controls organized by implementation domain (identity, runtime, data, governance, audit and accountability) and tagged by function (preventive, detective, corrective, deterrent). Each control is mapped to the threats it addresses, to relevant articles of the EU AI Act, NIS2, DORA, and GDPR, and to the closest equivalents in NIST SP 800-53 Rev. 5, ISO 27001 Annex A, and BSI grundschutz. The intent is breadth and readability: a CISO should be able to scan the library in one sitting and identify which controls are relevant to their deployment.

The methodology, per-control template, taxonomy, and consolidation rules are documented in `docs/frameworks/CONTROL_LIBRARY_FRAMEWORK.md`. That framework is the authoritative reference for how the library is structured and how new controls are added or refined. This section presents the controls themselves; the framework explains why they look the way they do.

The current v1 library status: CTL-001, CTL-002, CTL-003, CTL-004, and CTL-005 are all fully populated (presented below). The v1 control library is complete at five controls. CTL-006 through CTL-015 are reserved IDs that will be populated in v2 as the library expands beyond the initial five.

CTL-001: Identity and Authorization Context Propagation

Domain: Identity **Function:** Preventive **Maturity:** Emerging

Description: An AI agent's effective authorization for any action must be derived from both its own service authorization and the authorization of the user it is currently serving. The agent does not act with its full service-level privileges; it acts with the intersection of its privileges and the originating user's. Identity and authorization claims about the user are propagated through every downstream call the agent makes, and downstream systems verify against the user's identity rather than the agent's alone.

Implementation pattern: At the agent runtime layer, every user request is associated with an authorization context that includes the user's verified identity, applicable claims (roles, group memberships, tenant), and any constraints derived from the session (time-bound, scope-bound). When the agent invokes a tool or downstream service, the request includes this context as structured data, typically as an OAuth 2.0 Token Exchange (RFC 8693) on-behalf-of token, a SPIFFE workload identity bound to the user session, or a custom signed claims envelope.

Downstream services authorize the action against the user identity, not the agent identity, using their existing authorization infrastructure. The agent identity is used only for the agent-to-service authentication leg; the action authorization is a separate decision based on the propagated user context. Where a downstream service does not natively support user-context-aware authorization, the agent must restrict its actions on that service to the narrowest scope acceptable to all users it serves, or refuse to integrate with that service for sensitive operations.

For multi-tenant deployments, tenant identity is part of the propagated context and must be enforced at every layer. For multi-step delegation chains, the user context is forwarded explicitly at each step; the chain breaks if any step strips or replaces it.

Operational considerations:

Consideration	Description
Latency	Token issuance and verification at each downstream call adds latency, typically 10 to 50 ms per hop; cumulative across delegation chains
Caching complexity	Per-user authorization scoping reduces the value of shared caches; caches must be partitioned by user, or invalidated on authorization changes
Legacy integration	Many enterprise systems do not support user-context-aware authorization; the agent must either widen its trust to those systems or exclude them from sensitive operations
Token lifetime tuning	Short-lived tokens improve security but increase issuance load; long-lived tokens reduce load but expand the window of compromise; typical compromise: minutes-scale lifetime with refresh
Audit volume	Per-user authorization decisions increase audit log volume substantially; storage and SIEM ingestion costs grow accordingly

Common failure modes:

Failure mode	Description
Service account fallback	Under integration pressure, the agent is configured to call a particular service with its own identity rather than the user's; the agent retains broad privileges and the user-context model is bypassed for that integration
Token scope drift	Initial deployment uses correctly scoped tokens; over time, scopes expand to accommodate new use cases without re-evaluating the original constraints
Caching across users	A naive cache of tool outputs is queried by all users; one user's authorized retrieval becomes accessible to other users via the cache
Delegation chain context loss	An agent invokes a sub-agent or external service that does not preserve the user context; the chain continues with the agent's identity rather than the user's
Static configuration vs dynamic context	The agent's authorization model is configured once at deployment; runtime changes to user permissions are not reflected in the agent's effective authorization

Threats addressed: AGT-002 (primary), AGT-001 (secondary, by limiting blast radius), AGT-005 (secondary, by enabling cleaner attribution).

Regulatory basis:

Regulation	Article or section	Relevance
EU AI Act	Art. 14	Human oversight; authorization scoping is a structural prerequisite for meaningful oversight
EU AI Act	Art. 15	Cybersecurity; resilience to unauthorized use requires user-context enforcement
NIS2	Art. 21	Access control policies; agents are critical assets requiring proportionate authorization controls
DORA	Art. 9	Identity management; financial entities must maintain robust identity and access controls
GDPR	Art. 5(1)(f)	Integrity and confidentiality; user-context propagation prevents cross-user data exposure
GDPR	Art. 25	Data protection by design; user-scoped authorization is a design-level control
GDPR	Art. 32	Security of processing; technical measures including access control

Existing standard mappings:

Standard	Control ID	Relationship
NIST SP 800-53 Rev. 5	AC-3 (Access Enforcement)	Refinement: AC-3 establishes the principle; CTL-001 extends to agent-mediated authorization specifically
NIST SP 800-53 Rev. 5	AC-6 (Least Privilege)	Refinement: least privilege applied to the agent-user composition
NIST SP 800-53 Rev. 5	IA-9 (Service Identification and Authentication)	Refinement: IA-9 covers service-to-service authentication; CTL-001 extends to user-context propagation through services
ISO 27001 Annex A	A.5.15 (Access control)	Refinement: extends to agent-mediated access
ISO 27001 Annex A	A.8.2 (Privileged access rights)	Refinement: privileged access scoping for agents
BSI grundschutz	ORP.4 (Identitäts- und Berechtigungsmanagement)	Refinement: identity and authorization management extended to agent context

Related controls:

Control	Relationship
CTL-003 (Action verification at high-impact boundaries)	Complementary: where CTL-001 cannot fully scope authorization, CTL-003 provides a fallback
CTL-004 (Authorization-aware output filtering)	Complementary: CTL-001 controls what data is retrieved; CTL-004 controls what is delivered to the user
CTL-005 (End-to-end audit and accountability)	Dependent: audit traceability requires the user-context propagation that CTL-001 provides

References:

- NIST SP 800-53 Rev. 5, Access Control family (AC-3, AC-6, IA-9)
- NIST SP 800-207, Zero Trust Architecture
- IETF RFC 8693, OAuth 2.0 Token Exchange
- IETF RFC 9068, JSON Web Token Profile for OAuth 2.0 Access Tokens
- BSI IT-Grundschutz-Kompendium, Baustein ORP.4 Identitäts- und Berechtigungsmanagement
- ISO/IEC 27001:2022, Annex A controls A.5.15 and A.8.2
- SPIFFE / SPIRE specifications for workload identity

CTL-002: Tool-Output and Context Provenance

Domain: Runtime **Function:** Preventive, Detective **Maturity:** Emerging

Description: Content returned by tools is structurally distinguished from instructions the agent should follow. The control creates an architectural boundary between data the agent processes and instructions the agent treats as authoritative. Without this boundary, adversarial content embedded in tool outputs (documents, web pages, retrieval results, sub-agent responses) can override the agent's original task. With it, the agent runtime maintains provenance metadata that prevents content from being elevated to instruction status.

The control exists because LLMs do not natively distinguish between content and instruction. Both arrive in the same context window as text. The distinction must be enforced at the runtime layer, not relied upon as a model behavior.

Implementation pattern: Tool outputs are wrapped in a structured envelope before entering the agent context. The envelope preserves provenance metadata: source tool identity, retrieval timestamp, source URL or document identifier, content type, and trust level (e.g., internal-trusted, internal-untrusted, external). The agent runtime processes wrapped content as data, not as authoritative instruction.

Three implementation styles are common:

Style	How it works
Tagged context	Tool outputs are inserted into the agent context with explicit markers (e.g., <code><tool_output source="web_fetch" trust="external"></code>); the system prompt instructs the model to treat content within these markers as data, not instruction
Structured envelope	Tool outputs are passed to the agent as structured objects (JSON, typed records) with provenance fields; the agent reasoning operates over the structure, not raw text
Runtime mediation	A runtime layer between the model and tool calls inspects outputs and either rejects, transforms, or annotates them before they reach the model context

The strongest implementations combine all three: structured envelopes at the runtime level, tagged context within the model prompt, and active runtime mediation for high-trust environments. For high-stakes deployments, the control extends to memory and persistence (memory writes carry provenance), to delegation chains (sub-agent outputs preserve their provenance through the chain), and to output channels (provenance metadata is referenced in audit logs).

Operational considerations:

Consideration	Description
Performance overhead	Envelope wrapping and provenance tracking add per-call overhead, typically 5 to 15 ms per tool invocation; cumulative across multi-tool workflows
Complexity of cross-tool aggregation	When the agent reasons across outputs from multiple tools, provenance must be preserved through aggregation; naive transformation strips it
Trust level definition	Defining what counts as internal-trusted versus external requires policy work; over-broad trust labels weaken the control
Model cooperation	Tagged-context approaches depend on the model respecting the markers; current LLMs do this imperfectly, especially under adversarial pressure
Audit volume	Provenance-rich logs are larger than traditional tool-call logs; storage and SIEM costs grow accordingly
Backward compatibility	Existing agent integrations may not pass provenance through; integration retrofits are real work

Common failure modes:

Failure mode	Description
Envelope stripping during transformation	The agent summarizes, translates, or otherwise transforms tool output, and the transformation removes provenance metadata; downstream the content is treated as agent-generated rather than tool-retrieved
Provenance loss across delegation chains	A sub-agent receives content with provenance, processes it, and emits output without preserving the original source attribution
Reliance on model self-discipline	Implementations that depend on model instructions to treat retrieved content as data rather than instruction without runtime enforcement; models comply most of the time but not adversarially
Trust label drift	Initial deployment labels external content as untrusted; over time, internal sources are added that should also be untrusted but are labeled as internal-trusted
Inconsistent envelope formats	Different tools wrap output differently; the agent runtime must normalize, and normalization can introduce errors
Memory bypass	Provenance is enforced at retrieval but stripped before content is written to memory; persisted content loses its provenance and is later retrieved as agent-authored

Threats addressed: AGT-001 (primary), AGT-006 (primary), AGT-008 (secondary), AGT-009 (secondary).

Regulatory basis:

Regulation	Article or section	Relevance
EU AI Act	Art. 15	Cybersecurity; resilience to manipulation through tool-output channels requires runtime-level provenance
EU AI Act	Art. 14	Human oversight; provenance metadata supports the reviewability that meaningful oversight requires
EU AI Act	Art. 10	Data and data governance; provenance is a data-quality control extended to runtime context
NIS2	Art. 21	Cybersecurity risk-management measures; agent runtimes processing variable-trust content fall within the directive's scope
DORA	Art. 6 to 8	ICT risk management; operational resilience for financial entities including resilience to runtime manipulation
GDPR	Art. 32	Security of processing; technical measures including resilience to manipulation of context content
GDPR	Art. 5(1)(d)	Accuracy; provenance is a precondition for assessing and maintaining accuracy of content the agent operates over

Existing standard mappings:

Standard	Control ID	Relationship
NIST SP 800-53 Rev. 5	SC-8 (Transmission Confidentiality and Integrity)	Refinement: SC-8 establishes integrity protection for transmissions; CTL-002 extends to integrity-of-attribution for tool outputs within agent runtimes
NIST SP 800-53 Rev. 5	SI-10 (Information Input Validation)	Refinement: SI-10 covers input validation generally; CTL-002 extends to the specific case of tool outputs as inputs to model reasoning
NIST SP 800-53 Rev. 5	SI-15 (Information Output Filtering)	Adjacent: SI-15 addresses output filtering; CTL-002 addresses input handling but uses similar provenance principles
ISO 27001 Annex A	A.8.26 (Application security requirements)	Refinement: application security extended to agent runtime requirements
ISO 27001 Annex A	A.8.28 (Secure coding)	Adjacent: secure coding principles applied to agent runtime envelope handling
BSI grundschutz	CON.10 (Webanwendungen und Webservices)	Adjacent: web application security extended to retrieval-tool integrations
BSI grundschutz	OPS.1.2.4 (Schutz vor Schadprogrammen)	Refinement: extended to agent-context-level content evaluation

Related controls:

Control	Relationship
CTL-001 (Identity and authorization context propagation)	Complementary: provenance addresses what content is; identity propagation addresses who the action is for
CTL-003 (Action verification at high-impact boundaries)	Complementary: when provenance flags untrusted content as influencing a high-impact action, action verification provides a checkpoint
CTL-005 (End-to-end audit and accountability)	Dependent: forensic review of injection-driven actions requires the provenance metadata that CTL-002 produces

References:

- NIST SP 800-53 Rev. 5, controls SC-8, SI-10, SI-15
- NIST SP 800-218 (Secure Software Development Framework), relevant for runtime input handling
- ISO/IEC 27001:2022, Annex A controls A.8.26 and A.8.28
- BSI IT-Grundschutz-Kompendium, Bausteine CON.10 and OPS.1.2.4
- IETF RFC 9421 (HTTP Message Signatures), relevant pattern for verifiable provenance metadata
- OWASP Top 10 for LLM Applications, LLM01 (Prompt Injection) and LLM03 (Training Data Poisoning) for context on the threat landscape
- MITRE ATLAS, AML.T0070 (Indirect Prompt Injection)
- Greshake et al., "Not What You've Signed Up For: Compromising Real-World LLM-Integrated Applications with Indirect Prompt Injection" (2023)

CTL-003: Action Verification at High-Impact Boundaries

Domain: Governance **Function:** Preventive **Maturity:** Emerging

Description: Before an agent executes an action that exceeds defined impact thresholds, the action is verified through an explicit checkpoint that is independent of the agent reasoning. The control inserts a governance boundary between agent intent and consequential action. Where automated controls cannot fully prevent a threat, this checkpoint is often the only fully reliable mitigation.

The control is governance-domain because the central work is policy: defining what counts as high-impact, how verification happens, who or what performs it, and what triggers escalation. The technical enforcement is straightforward once policy is clear; the policy itself requires deliberate organizational decisions that cannot be automated.

Implementation pattern: Define impact thresholds across multiple dimensions: financial (transaction value, cumulative cost), reputational (external communications, customer-facing decisions), regulatory (actions touching regulated data or processes), irreversibility (data deletion, contract execution, public statements), and cumulative composition (sequences of individually small actions producing high-impact outcomes).

For any action exceeding a threshold, the agent must obtain verification before proceeding. Verification can take several forms:

Verification mode	Use case
Human approval (human-in-the-loop)	Highest-stakes actions; irreversible decisions; regulated environments where automation alone is not permitted
Out-of-band confirmation	User confirms via secondary channel (email, push notification, signed token); appropriate where the user is the originating actor
Secondary agent review	A second agent with different prompts, different context, or different authorization reviews the proposed action; useful at scale where human approval does not
Policy engine check	Automated rule evaluation against a policy; appropriate for well-defined, repeatable threshold tests
Multi-step delay with notification	Action is queued for a defined window during which it can be canceled; appropriate for moderate-impact actions where review is desirable but not essential

The control extends to composed actions. A sequence of low-impact actions that together produce a high-impact outcome must be detected and verified at the composition boundary, not only at the individual action level. This requires the agent runtime to track cumulative effect, not just per-call thresholds. For high-stakes deployments, verification is layered: a policy engine handles the high-volume routine cases, secondary agent review handles the medium-volume novel cases, and human approval handles the low-volume highest-stakes cases.

Operational considerations:

Consideration	Description
Latency	Verification adds latency, ranging from milliseconds (policy engine) to hours or days (human approval); this directly affects user experience and must be designed into the workflow
Threshold calibration	Thresholds must be tuned to organizational risk tolerance; too low and verification becomes routine and ignored, too high and meaningful actions slip through
Verification fatigue	Reviewers exposed to many verifications develop rubber-stamping behavior; design must include sampling, randomization, or explicit attention prompts
Cumulative effect tracking	Tracking composed actions requires runtime instrumentation that many agent platforms do not natively support
Threshold drift	Policy thresholds set at deployment can become stale as products, regulations, and risk environment evolve; periodic governance review is essential
Workaround risk	Agents under instruction or pressure may find paths to achieve the same outcome through actions that individually fall below thresholds; CTL-003 alone does not prevent this
Cross-organization variance	What counts as high-impact varies dramatically across regulated sectors; the control framework requires sector-specific policy work

Common failure modes:

Failure mode	Description
Threshold definitions becoming stale	Initial thresholds reflect deployment-time assumptions; product changes, regulatory changes, and threat landscape evolution make them inadequate over time
Rubber-stamping	Reviewers process too many verifications too quickly; the verification becomes formal rather than meaningful
Per-action thresholds without composition	Thresholds catch single high-impact actions but miss sequences of low-impact actions producing similar outcomes
Verification path bypass	Agents discover paths that achieve the goal through tools or sequences not covered by threshold rules
Policy engine staleness	Automated rules are written once and not maintained; new action types fall outside the rules and proceed without verification
Out-of-band channel compromise	Confirmation channels (email, SMS) are themselves attackable; under sophisticated attack, the confirmation step can be defeated
Misaligned verification authority	The reviewer lacks the context, authority, or training to evaluate the action meaningfully; the verification is procedural rather than substantive

Threats addressed: AGT-001 (primary), AGT-002 (primary), AGT-003 (primary), AGT-008 (primary), AGT-009 (secondary), AGT-010 (secondary).

Regulatory basis:

Regulation	Article or section	Relevance
EU AI Act	Art. 14	Human oversight; the regulatory anchor for human-in-the-loop verification at high-impact boundaries
EU AI Act	Art. 15	Cybersecurity; resilience to manipulation requires verification gates for consequential actions
EU AI Act	Art. 9	Risk management system; high-impact actions require proportionate verification controls
NIS2	Art. 21	Cybersecurity risk-management measures; action-boundary verification is a structural risk control
DORA	Art. 6 to 9	ICT risk management and identification of critical functions requiring proportionate verification
GDPR	Art. 22	Automated individual decision-making; verification is the structural mechanism for the right to human review
GDPR	Art. 32	Security of processing; verification at high-impact boundaries is a technical and organizational measure

Existing standard mappings:

Standard	Control ID	Relationship
NIST SP 800-53 Rev. 5	AC-3 (Access Enforcement)	Refinement: AC-3 establishes the principle of enforcing approved authorizations; CTL-003 extends to action-level verification beyond identity-based authorization
NIST SP 800-53 Rev. 5	CA-7 (Continuous Monitoring)	Refinement: continuous monitoring extended to agent action streams
NIST SP 800-53 Rev. 5	AC-21 (Information Sharing)	Adjacent: information-sharing decisions are a class of high-impact action that CTL-003 covers
NIST SP 800-53 Rev. 5	SI-4 (System Monitoring)	Adjacent: system monitoring extended to agent action patterns
ISO 27001 Annex A	A.5.36 (Compliance with policies, rules and standards)	Refinement: policy compliance enforced at the action boundary
ISO 27001 Annex A	A.8.7 (Protection against malware)	Adjacent: extended to protection against agent-driven actions exceeding authorization scope
BSI grundschutz	ORP.1 (Organisation)	Refinement: organizational governance extended to agent action governance
BSI grundschutz	ORP.4 (Identitäts- und Berechtigungsmanagement)	Adjacent: identity and authorization management extended to action verification

Related controls:

Control	Relationship
CTL-001 (Identity and authorization context propagation)	Complementary: CTL-001 limits what the agent is authorized to do; CTL-003 verifies high-impact actions within that authorization
CTL-002 (Tool-output and context provenance)	Complementary: provenance metadata informs the verification decision; untrusted-content-influenced actions warrant stricter verification
CTL-005 (End-to-end audit and accountability)	Dependent: verification decisions must be auditable; CTL-005 captures the verification record

References:

- NIST SP 800-53 Rev. 5, controls AC-3, AC-21, CA-7, SI-4
- NIST SP 800-37 Rev. 2, Risk Management Framework, for governance context
- ISO/IEC 27001:2022, Annex A controls A.5.36 and A.8.7
- ISO/IEC 38500:2024, Governance of information technology, for organizational governance principles applicable to agent governance
- BSI IT-Grundschutz-Kompendium, Bausteine ORP.1 and ORP.4
- EU AI Act, Article 14 (Human oversight), as the regulatory anchor for human-in-the-loop verification at high-impact boundaries
- DORA, Articles 6 to 9, for ICT risk management and identification of critical functions requiring proportionate verification

CTL-004: Authorization-Aware Output Filtering

Domain: Data **Function:** Preventive **Maturity:** Emerging

Description: Agent outputs are filtered against the requesting user's authorization context before delivery, regardless of what the agent retrieved. The control closes the gap between agent retrieval scope and user authorization. Even when an agent has retrieved data using broader privileges than the user holds (a common operational reality), the output the user receives is constrained to what they are independently authorized to see.

The control operates at the output boundary, downstream of agent reasoning. It is structurally distinct from retrieval authorization: retrieval determines what the agent can read, output filtering determines what the user can see. Both are needed because in many enterprise deployments the agent must read broadly to perform its task, but users served by the agent have differentiated authorization.

Implementation pattern: After the agent has composed its proposed response and before delivery to the user, an output filter applies the user authorization context to the response. The filter has access to the user identity, the user's authorization claims (roles, group memberships, tenant, sensitivity clearances), and the data sources or content elements that contributed to the response.

Three implementation styles are common:

Style	How it works
Source-based filtering	Each content element in the proposed output is tagged with its source; the filter removes elements from sources the user is not authorized to access
Attribute-based filtering	Output content is classified at filter time (PII type, sensitivity level, regulatory category); the filter compares classifications against user authorization and redacts non-authorized content
Hybrid filtering	Source tags provide the primary signal; attribute-based filtering catches inferential disclosure where source attribution is insufficient

The filter must handle three distinct disclosure modes: direct quotation (content from a non-authorized source appears verbatim, which source-based filtering catches reliably); paraphrase or summary (content is rephrased but conveys the same protected information, which source-based filtering may miss and attribute-based filtering may catch); and inferential disclosure (content composed from authorized sources reveals protected information through inference, for example aggregating individually permitted records into a profile that would not have been permitted directly; both filtering styles struggle here, and this is where CTL-004 has known limits).

For high-stakes deployments, the filter extends to non-user-facing output channels: log entries, telemetry, audit records, and persistence to memory or vector stores. Output filtering at the user boundary alone is insufficient if the same content reaches other systems unfiltered.

Operational considerations:

Consideration	Description
Performance overhead	Output filtering adds latency, typically 20 to 100 ms per response depending on filter complexity; cumulative for streaming or multi-turn responses
User context dependency	Filtering requires the user authorization context to be available at the output boundary; if CTL-001 is not implemented, the filter has insufficient information
Inferential disclosure limits	Current filtering technology cannot reliably detect when a paraphrased or composed response reveals protected information; this is a known limit, not an implementation defect
Content classification accuracy	Attribute-based filtering depends on classifiers (PII detectors, sensitivity classifiers); their accuracy varies and false negatives produce real disclosure
Channel coverage	Filtering only the user-facing channel leaves logs, telemetry, audit records, and persisted state unfiltered; full coverage requires deliberate channel inventory
Authorization model complexity	Enterprises with role-based, attribute-based, or relationship-based authorization need filter logic that mirrors the production authorization model; mismatches produce inconsistent behavior
Streaming output	Real-time streaming responses are harder to filter than complete responses; partial filtering during streaming risks revealing protected content before the filter completes

Common failure modes:

Failure mode	Description
Filtering only direct quotes	The filter catches verbatim disclosure but misses paraphrase and summary; the agent reveals protected information in its own words
Inference leaks	Composed responses reveal protected information through inference even when no individual content element is unauthorized
Channel bypass	Output filtering applies to the user response but logs, telemetry, audit records, or persistence include the unfiltered content
User context unavailable at filter time	The filter runs but cannot evaluate authorization because the user identity or claims were not propagated; the filter fails open or fails closed inconsistently
Classifier false negatives	Attribute-based filters miss content the classifier was not trained for; novel sensitive categories evade detection
Authorization model drift	Filter logic was implemented against a production authorization model; the production model evolves but the filter logic does not
Permission-denied notice as oracle	When the filter redacts content, the resulting permission-denied notice itself reveals that protected content existed; this can be a disclosure in regulated contexts

Threats addressed: AGT-002 (primary), AGT-004 (primary), AGT-008 (secondary).

Regulatory basis:

Regulation	Article or section	Relevance
GDPR	Art. 5(1)(c)	Data minimization; the regulatory anchor for output filtering as a data protection principle
GDPR	Art. 25	Data protection by design and by default; design-level requirement to filter outputs to the minimum necessary
GDPR	Art. 32	Security of processing; technical measures including access control at output
EU AI Act	Art. 10	Data and data governance; output filtering enforces data governance at the agent output boundary
EU AI Act	Art. 15	Cybersecurity; filtering reduces unauthorized disclosure as a security outcome
NIS2	Art. 21	Cybersecurity risk-management measures; output filtering is a structural confidentiality control
DORA	Art. 6 to 8	ICT risk management; operational resilience including confidentiality controls at agent output

Existing standard mappings:

Standard	Control ID	Relationship
NIST SP 800-53 Rev. 5	AC-3 (Access Enforcement)	Refinement: AC-3 establishes access enforcement; CTL-004 extends enforcement to the output boundary as a distinct point of control
NIST SP 800-53 Rev. 5	AC-21 (Information Sharing)	Refinement: information-sharing decisions enforced at the agent output boundary
NIST SP 800-53 Rev. 5	SC-8 (Transmission Confidentiality and Integrity)	Adjacent: confidentiality of transmission extended to filtering of agent outputs
NIST SP 800-53 Rev. 5	SI-15 (Information Output Filtering)	Direct equivalent: SI-15 is specifically about output filtering; CTL-004 is its application to agent runtimes
ISO 27001 Annex A	A.5.10 (Acceptable use of information)	Refinement: acceptable use enforced at the output boundary of agent systems
ISO 27001 Annex A	A.8.12 (Data leakage prevention)	Refinement: data leakage prevention applied to agent-mediated output
BSI grundschutz	CON.6 (Löschen und Vernichten von Daten)	Adjacent: data minimization principles extended to output filtering
BSI grundschutz	CON.2 (Datenschutz)	Refinement: data protection principles applied to agent output

Related controls:

Control	Relationship
CTL-001 (Identity and authorization context propagation)	Dependent: filter operation requires the user authorization context that CTL-001 propagates; without CTL-001, the filter has insufficient information
CTL-002 (Tool-output and context provenance)	Complementary: provenance metadata helps the filter identify which content elements came from which sources for source-based filtering
CTL-005 (End-to-end audit and accountability)	Complementary: filter decisions (what was filtered, why, for whom) are themselves auditable events that CTL-005 captures

References:

- NIST SP 800-53 Rev. 5, controls AC-3, AC-21, SC-8, SI-15
- NIST SP 800-122, Guide to Protecting the Confidentiality of Personally Identifiable Information
- ISO/IEC 27001:2022, Annex A controls A.5.10 and A.8.12
- ISO/IEC 27018:2019, Code of practice for protection of personally identifiable information in public clouds
- BSI IT-Grundschutz-Kompendium, Bausteine CON.2 and CON.6
- GDPR, Article 5(1)(c) (Data minimization), as the regulatory anchor for output filtering as a data protection principle
- GDPR, Article 25 (Data protection by design and by default), for design-level requirement to filter outputs to the minimum necessary
- GDPR, Article 32 (Security of processing), for technical measures including access control at output

CTL-005: End-to-End Audit and Accountability

Domain: Audit and accountability **Function:** Detective, Corrective **Maturity:** Emerging (operational logs); Experimental (reasoning provenance)

Description: Every agent action is traceable to the originating user, the agent involved, the delegation chain (where applicable), the data and context that informed the decision, and the authorization basis on which the action was taken. The control enables forensic review, regulatory reporting, accountability for agent-mediated harm, and the detection of patterns that span multiple actions or users.

The control is detective and corrective rather than preventive: it does not stop bad things from happening, but it makes them visible after the fact and provides the basis for remediation. In agent contexts this matters more than in traditional systems because agent behavior is emergent and individual actions may look benign in isolation. Without end-to-end audit, organizations cannot answer fundamental accountability questions when something goes wrong.

The control distinguishes itself from traditional logging by capturing five dimensions of provenance simultaneously: who initiated the action (user attribution), what acted (agent attribution including delegation chain), what informed the decision (context provenance, retrieved data, instructions), what reasoning produced the action (model reasoning where available), and on what authority (authorization basis).

Implementation pattern: Audit records are structured to capture the full provenance chain for each agent action. A typical record includes:

Dimension	What is captured
User attribution	Verified user identity, session identifier, authentication method, request that initiated the chain
Agent attribution	Agent service identity, agent version or model identifier, delegation chain if multiple agents are involved
Context provenance	Tools invoked, tool outputs received with their provenance metadata (from CTL-002), retrieved documents with version or revision identifiers, system prompts active at the time
Decision provenance	Model reasoning where available (chain-of-thought, tool selection rationale), policy decisions consulted, alternative paths considered
Authorization basis	The user authorization context that applied (from CTL-001), the verification that occurred at action boundaries (from CTL-003), the output filter decisions that were made (from CTL-004)
Action and outcome	The action taken, the system that received it, the result, and any downstream effects

Records are correlated across systems through consistent identifiers: session ID, request ID, agent invocation ID, tool call ID. Without correlation, forensic reconstruction becomes prohibitively expensive.

For high-stakes deployments, audit extends to memory and persistence operations: every write to memory or vector stores is logged with the user, agent, and context that produced it, enabling later investigation when persisted content influences subsequent agent behavior.

The control acknowledges a fundamental limit: model reasoning provenance is partially opaque. Current LLMs do not produce reliable, deterministic explanations of their own decisions. Audit records should capture what reasoning the model emitted (where it produces chain-of-thought) but should not fabricate reasoning where none was emitted. This is a documented limit, not an implementation defect.

Operational considerations:

Consideration	Description
Log volume	Provenance-rich records are substantially larger than traditional application logs; storage costs grow accordingly, often by an order of magnitude
SIEM ingestion cost	Most enterprise SIEMs are priced by ingestion volume; agent audit records compound the cost
Correlation infrastructure	Cross-system correlation requires consistent identifier propagation, which often requires retrofit of existing logging infrastructure
Reasoning provenance limits	Where the model does not emit reasoning, the audit record cannot synthesize it; this must be documented honestly rather than papered over
Retention policy alignment	Regulatory retention requirements (GDPR data subject rights, DORA incident reconstruction, sector-specific audit retention) drive retention, not internal preference
Privacy of audit records	Audit records often contain personal data and sensitive content; the audit infrastructure itself becomes a high-value target requiring its own access control
Detection at scale	Surfacing useful patterns from agent audit volumes requires detection rules tuned for agent behavior, which most enterprise SOC tooling does not yet have
Real-time vs batch	Real-time logging affects performance; batch logging risks loss during incidents; deployments must choose deliberately

Common failure modes:

Failure mode	Description
Logs fragmented across systems	Each component logs to its own destination with no common correlation key; reconstruction requires manual joins that are infeasible at scale
User attribution lost when CTL-001 is not implemented	Logs record the agent acted but cannot link to the originating user; accountability is broken at the foundation
Reasoning provenance fabricated	Implementations that synthesize plausible-sounding reasoning when the model did not emit any; gives false confidence in interpretability
Retention policies inconsistent with regulatory requirements	Logs are retained per IT policy rather than per regulatory obligation; data subject rights or incident-reconstruction requests cannot be fulfilled
Memory and persistence operations not audited	Direct user-facing actions are logged but writes to vector stores or long-term memory are not; later investigation cannot trace influence back to origin
Audit records exposed	Logs are stored without access control proportionate to their content; the audit infrastructure becomes a privacy or security incident in itself
Detection rules absent	Logs exist but no detection logic surfaces patterns; audit becomes forensic-only, not preventive
Volume-induced sampling	Cost pressures lead to sampling that breaks reconstruction integrity; sampling must be deliberate and documented, not silent

Threats addressed: AGT-005 (primary), AGT-004 (primary), AGT-001 (secondary), AGT-002 (secondary), AGT-003 (secondary), AGT-006 (secondary), AGT-007 (secondary), AGT-009 (secondary), AGT-010 (secondary).

Regulatory basis:

Regulation	Article or section	Relevance
EU AI Act	Art. 12	Record-keeping; AI-specific logging requirements applicable to high-risk systems
EU AI Act	Art. 13	Transparency; the information-about-system-operation requirement that audit supports
GDPR	Art. 5(2)	Accountability; the foundational requirement that audit enables
GDPR	Art. 30	Records of processing activities; formal record-keeping obligation that overlaps with agent audit
NIS2	Art. 21	Cybersecurity risk-management measures; logging and monitoring as structural controls
NIS2	Art. 23	Incident reporting; reporting obligations depend on audit data being available
DORA	Art. 12	Major ICT-related incidents; regulatory anchor for incident reconstruction obligations
DORA	Art. 17 to 19	ICT-related incident management, classification, and reporting; all depend on audit

Existing standard mappings:

Standard	Control ID	Relationship
NIST SP 800-53 Rev. 5	AU-2 (Event Logging)	Refinement: event logging extended to agent actions and decisions
NIST SP 800-53 Rev. 5	AU-3 (Content of Audit Records)	Refinement: audit content extended to capture user, agent, context, and reasoning provenance
NIST SP 800-53 Rev. 5	AU-6 (Audit Record Review, Analysis, and Reporting)	Refinement: review extended to agent-specific patterns
NIST SP 800-53 Rev. 5	AU-9 (Protection of Audit Information)	Refinement: audit protection acknowledging audit records contain sensitive agent context
NIST SP 800-53 Rev. 5	AU-12 (Audit Record Generation)	Refinement: record generation across agent runtime, tools, model invocations, and persistence
NIST SP 800-53 Rev. 5	IR-4 (Incident Handling)	Adjacent: incident handling depends on the audit data CTL-005 produces
ISO 27001 Annex A	A.8.15 (Logging)	Refinement: logging extended to agent provenance
ISO 27001 Annex A	A.8.16 (Monitoring activities)	Refinement: monitoring extended to agent behavior patterns
ISO 27001 Annex A	A.5.28 (Collection of evidence)	Refinement: evidence collection extended to agent reasoning and provenance
BSI grundschutz	OPS.1.1.5 (Protokollierung)	Refinement: logging principles extended to agent runtime
BSI grundschutz	DER.1 (Detektion von sicherheitsrelevanten Ereignissen)	Refinement: detection extended to agent-specific patterns

Related controls:

Control	Relationship
CTL-001 (Identity and authorization context propagation)	Dependent: user attribution in audit records requires identity propagation; without CTL-001, audit cannot attribute reliably
CTL-002 (Tool-output and context provenance)	Dependent: context provenance in audit records requires the metadata that CTL-002 produces
CTL-003 (Action verification at high-impact boundaries)	Complementary: verification decisions are audit events; CTL-005 captures them
CTL-004 (Authorization-aware output filtering)	Complementary: filter decisions are audit events; CTL-005 captures them

References:

- NIST SP 800-53 Rev. 5, AU family controls (AU-2, AU-3, AU-6, AU-9, AU-12), IR-4
- NIST SP 800-92, Guide to Computer Security Log Management
- NIST SP 800-61 Rev. 2, Computer Security Incident Handling Guide
- ISO/IEC 27001:2022, Annex A controls A.5.28, A.8.15, A.8.16

- ISO/IEC 27037:2012, Guidelines for identification, collection, acquisition and preservation of digital evidence
- BSI IT-Grundschutz-Kompendium, Bausteine OPS.1.1.5 and DER.1
- DORA, Article 12 (Major ICT-related incidents), as the regulatory anchor for incident reconstruction obligations
- EU AI Act, Article 12 (Record-keeping), for AI-specific logging requirements applicable to high-risk systems
- EU AI Act, Article 13 (Transparency), for the information-about-system-operation requirement that audit supports
- GDPR, Article 5(2) (Accountability), as the foundational requirement that audit enables
- GDPR, Article 30 (Records of processing activities), for the formal record-keeping obligation that overlaps with agent audit

7. Implementation Considerations

This section addresses how to deploy the v1 controls in environments that already have an established security program. The five subsections track the high-leverage decisions: where the controls plug into existing architecture, how to design the human review surface, where to place output filtering, how to roll out controls without exposing the organization to unnecessary risk, and how the controls produce evidence for regulatory obligations. Known gaps in the v1 control library are documented in Section 8 and are not revisited here.

7.1 Mapping controls to existing security architecture

Most organizations subject to NIS2 or DORA already operate identity, audit, and content security infrastructure. The v1 controls do not replace any of it; they extend it across the agent execution boundary. The integration patterns that work consistently in practice are:

v1 control	Integrates with	Integration pattern
CTL-001 (Identity and authorization context propagation)	Existing IdP (Entra ID, Okta, Ping); existing OAuth / token-exchange infrastructure	The agent runtime acts as a downstream service in the token-exchange chain. The originating user's authorization context is carried forward as a delegated assertion (RFC 8693 token exchange or equivalent) rather than replaced with an agent service identity. The pattern that fails: the agent uses a service account with broad authorization and re-authorizes per call. The pattern that works: the agent inherits user context and the downstream tools enforce per-user authorization on retrieval.
CTL-002 (Tool-output and context provenance)	Existing data classification and DLP infrastructure	Provenance metadata is attached to content at ingest into the agent runtime and persisted through the execution. The agent runtime is responsible for distinguishing instruction from content; downstream consumers (including the model itself in subsequent turns) read the provenance tags. The pattern that fails: provenance lives only in agent logs after the fact. The pattern that works: provenance is part of the in-flight context and structurally distinguishes content from instruction at every boundary.
CTL-005 (End-to-end audit and accountability)	Existing SIEM (Splunk, Sentinel, Elastic); existing log retention infrastructure	Agent audit events flow into the existing SIEM as a new log source with a defined schema. The schema must include user attribution, tool invocation, retrieval scope, and decision provenance. The pattern that fails: agent logs as opaque blobs that the SOC cannot correlate with other security events. The pattern that works: agent logs as first-class structured events that the SOC can query alongside identity, network, and endpoint logs.

The integration questions worth answering during design rather than discovering during operation:

Question	Why it matters
Does the agent runtime have a service identity that the IdP can recognize as a delegated principal?	If not, CTL-001 cannot be implemented correctly; the agent will run with broad authorization and the deputy problem becomes structural
Does the SIEM ingest schema accommodate the cardinality of agent audit events?	A single user request can produce dozens of agent audit events; the SIEM must handle the volume without dropping or downsampling
Does the existing data classification taxonomy distinguish content origin?	If not, CTL-002 has no taxonomy to attach to; provenance becomes a parallel system rather than an extension of the existing one

CTL-003 and CTL-004 integrate with workflow and content systems respectively; their integration considerations are covered in subsections 7.2 and 7.3.

7.2 Approval queue design for high-impact actions

CTL-003 places verification at high-impact action boundaries. The control specification does not prescribe the user experience; that is an operational decision with two failure modes.

The first failure mode is over-broad approval scope. If every agent action requires approval, operators ignore the queue. The agent provides no efficiency benefit and the organization has merely added a slow human step to a workflow that did not need automation. This is alert fatigue applied to approvals.

The second failure mode is under-broad approval scope. If only the most consequential actions require approval (large fund transfers, account deletions), the agent operates autonomously across a large surface where authorization confusion (AGT-002), tool-chain abuse (AGT-003), and goal drift (AGT-009) can produce harm without verification. The threshold appears to be set conservatively but is in fact the lower bound below which technical controls must work alone.

The patterns that hold up in practice:

Approach	When it works	When it does not
Threshold based on action type alone (e.g., all fund transfers above EUR 10,000)	Actions are individually meaningful and the threshold reflects organizational risk tolerance	Actions compose; no single action exceeds the threshold but the composite does
Threshold based on cumulative effect (CTL-003's composition tracking)	Action composition is the dominant risk; AGT-003 is in scope	Operators cannot interpret cumulative thresholds; the queue surfaces opaque "cumulative limit reached" alerts
Threshold based on confidence (the agent's stated certainty about the action)	The model is well-calibrated and produces honest confidence signals	Models tend to be overconfident; thresholds based on stated confidence underapprove
Threshold based on user-context delta (the action affects users beyond the originating user)	AGT-002 (deputy problem) is the dominant risk	Single-user agents where the user always affects only themselves

The approval surface itself is a design problem distinct from the threshold. Three properties worth designing for:

Property	Why
The operator can see what the agent intends to do without re-reading the full conversation	Approvals must be possible in seconds, not minutes; the action description is the unit of decision
The operator can see the bridging context that makes the action high-impact	Why is this action surfacing for approval? Cumulative threshold? User-context delta? Without this, the operator cannot calibrate intuition over time
The operator can deny the action without ending the agent session	Hard-stop denial is rarely the right answer; "deny this action, propose an alternative" is. The approval surface must support negotiation

Approval queue design is where the framework most acutely depends on factors outside its scope (operator training, organizational risk tolerance, audit retention policy). Subsection 4.7 of the crosswalk and Section 8 acknowledge that human factors are out of scope for v1; this subsection treats the approval surface as a technical artifact while flagging that the human side is the dominant determinant of effectiveness.

7.3 Output filtering placement decisions

CTL-004 (authorization-aware output filtering) produces a structural choice: where in the request lifecycle does filtering apply?

The two viable placements:

Placement	Mechanism	Tradeoffs
Pre-retrieval filtering	The agent's retrieval calls are scoped to the user's authorization at the data layer (database row-level security, vector store metadata filters, search index ACLs)	Strongest guarantee; the agent cannot retrieve what it cannot see. Requires the data layer to enforce per-user authorization, which is often the existing access control architecture. Works only when the agent's retrieval interface respects the authorization model
Post-retrieval filtering	The agent retrieves with broad authorization and the output is filtered against the user's authorization before delivery	Weaker guarantee; the agent has temporarily seen content the user cannot see, creating residual risk through caching, logging, and side effects. Necessary when the data layer cannot enforce per-user authorization (e.g., document corpora with no per-user metadata)

The combination that works: pre-retrieval filtering as the primary mechanism, post-retrieval filtering as a defense-in-depth layer for content classes where pre-retrieval cannot be enforced. The combination that creates the deputy problem at scale: post-retrieval filtering only, with the agent operating against a corpus that includes content for many users.

A practical signal that the placement is wrong: the audit trail (CTL-005) shows the agent retrieving content the user is not authorized for, even though the user never saw it. This is structurally equivalent to AGT-004 (data exfiltration via legitimate channels) at the model layer; the model has been exposed to the content and may surface it in subsequent turns through paraphrase or summarization that defeats post-retrieval filtering.

7.4 Phased rollout patterns

Agent deployments fail more often through scope expansion than through technical inadequacy. The pattern: a successful pilot with narrow tool authorization expands to broader tool authorization, broader user populations, or higher-stakes use cases without the corresponding investment in CTL-001 and CTL-003. The framework cannot prevent this organizationally, but the rollout phasing can make the expansion decision visible.

The phasing that works in regulated environments:

Phase	Tool authorization	User population	Action surface	What gets validated
Pilot	Read-only against a single domain	Internal users with administrator visibility into agent behavior	Information retrieval; no consequential actions	CTL-001 propagation; CTL-005 audit completeness
Expansion 1	Read-only across multiple domains; structured write to a single domain	Broader internal users	Limited consequential actions, all under CTL-003 verification	CTL-002 provenance under cross-domain retrieval; CTL-003 threshold calibration
Expansion 2	Structured write across multiple domains	Internal users in operational roles	Consequential actions with selective CTL-003 verification based on calibrated thresholds	CTL-004 output filtering under broader authorization scopes; CTL-001 under multi-tenant or cross-organizational contexts
Production	Full deployed scope	Production user population	Full action surface	Continuous monitoring against the audit baseline established in earlier phases

The decision criteria for moving between phases are organization-specific and not prescribed here. The decision criteria for not moving between phases are universal:

Signal	What it indicates
CTL-005 audit shows authorization context drift across the pilot phase	CTL-001 implementation is incomplete; expansion will compound the gap
CTL-003 approval queue shows operator override patterns inconsistent with declared thresholds	Threshold calibration is wrong; expansion will produce alert fatigue
CTL-002 provenance failures are present in the audit trail	The agent is treating content as instruction in some path; expansion increases AGT-001 exposure
CTL-004 post-retrieval filtering is catching unauthorized content at non-trivial rate	Pre-retrieval filtering is not working; the data layer authorization model needs to be addressed before expansion

Rollback triggers are simpler. Any of the four signals above, observed at production scale, is a rollback trigger to the previous phase. Rolling back is not a failure; rolling forward through the signals is.

7.5 Regulatory evidence collection

The crosswalk in Section 4 maps regulatory requirements to v1 controls. This subsection addresses the operational counterpart: what evidence the controls produce, and how that evidence connects to specific regulatory obligations.

Evidence is produced as a byproduct of correct operation, not as a separate compliance activity. If the controls are operating, the evidence exists. If the evidence does not exist, the controls are not operating. This is the structural relationship that makes the framework useful for compliance work; it is not a guarantee that the evidence is sufficient for any specific obligation, which depends on the regulator's interpretation and the deployer's broader compliance program.

Regulatory obligation	Evidence the v1 controls produce	Operational source
EU AI Act Article 12 (record-keeping)	Automatically generated logs over the system lifecycle, including user attribution, tool invocation, retrieval scope, and decision provenance	CTL-005 audit stream; CTL-001 user attribution; CTL-002 retrieval and reasoning provenance
EU AI Act Article 14 (human oversight)	Approval queue records showing actions surfaced for human review, the operator decision (approve, deny, modify), and the timestamps for both	CTL-003 approval queue logs; CTL-005 audit of operator actions
EU AI Act Article 15 (accuracy, robustness, cybersecurity)	Audit-derived metrics on agent behavior under varied inputs; provenance trail for incidents involving content manipulation	CTL-002 provenance; CTL-005 audit; CTL-003 verification outcomes
NIS2 Article 21 (cybersecurity risk-management measures)	Evidence of access control enforcement (CTL-001), audit completeness (CTL-005), and operational monitoring derived from the audit stream	CTL-001 propagation logs; CTL-005 audit stream feeding the SIEM
NIS2 Article 23 (incident reporting)	Audit data sufficient to reconstruct events for the 24-hour, 72-hour, and one-month reporting cycles	CTL-005 audit retention with structured event schema
DORA Article 12 (major ICT-related incidents)	Audit data sufficient to reconstruct incident events; user and agent attribution for affected actions	CTL-005 with retention aligned to DORA reporting timelines
DORA Articles 28 to 30 (ICT third-party risk)	Audit and provenance data covering sub-agent and third-party tool invocations	CTL-001 across third-party tool boundaries; CTL-002 provenance across sub-agent outputs; CTL-005 audit of delegation chains
GDPR Article 5(2) (accountability)	End-to-end audit trail demonstrating compliance with processing principles	CTL-005 audit; CTL-002 provenance
GDPR Article 22 (automated individual decision-making)	Approval queue records demonstrating that decisions are not "solely" automated where Article 22 applies; audit trail supporting data subject contestability rights	CTL-003 approval queue; CTL-005 audit
GDPR Article 32 (security of processing)	Evidence of access control enforcement, output filtering, and incident audit consistent with appropriate technical measures	CTL-001, CTL-004, CTL-005

The evidence-collection decisions worth making during design:

Decision	Why it matters
Audit retention period	Must accommodate the longest reporting cycle the organization is subject to (typically DORA's structured incident reporting or NIS2 Article 23's one-month final report). Under-retention forecloses compliance options
Schema versioning for audit events	Regulatory requirements evolve; audit schemas must accommodate evolution without re-deriving evidence from the past. Schema-versioned events are queryable across schema generations
Separation of audit data from operational data	Operational logs are often retained on a different cycle and with different access controls than compliance audit. Treating these as the same store creates retention conflicts and access-control conflicts
Read-only access for compliance and audit functions	Compliance reviewers need access to the audit stream that does not require operational privileges. The access pattern that fails: compliance asks operations for a one-time data extract, which then ages and is not reproducible

For the cross-reference between specific articles and specific controls, see Section 4 (Common-control crosswalk). For known gaps in the v1 control library that affect what evidence can be produced, see Section 8 (Gaps and open problems).

8. Gaps and Open Problems

A framework that overstates its coverage will be discovered by serious readers. The credibility of the rest of this document depends on this section being honest about what is missing and why. The categories below are the limits worth naming, with practical implications for how practitioners should use the framework today.

8.1 The threat catalog is not exhaustive

The 10 named threats in section 5 are exemplars within the attack surface taxonomy, not a complete enumeration. The durable contribution is the taxonomy and the threat-discovery methodology in section 5; the named threats illustrate the patterns. Practitioners who address all 10 exemplars have addressed 10 illustrative patterns, not agent security as a whole. Coverage requires applying the methodology to the specific deployment.

The catalog will grow as deployments mature and new patterns become recognizable. v2 of this framework will revisit the exemplar list based on field experience.

8.2 The v1 control library has known coverage gaps

The five v1 controls cover the threat catalog with deliberate honesty about where coverage is partial.

Threat	Coverage in v1	Gap
AGT-003 (tool-chain abuse)	Partial	CTL-003 was designed for individual high-impact actions; extension to composed actions requires runtime instrumentation v1 does not specify
AGT-006 (memory and persistence poisoning)	Partial	CTL-002 covers tool-output provenance; memory and vector store provenance follows similar principles but needs its own treatment
AGT-008 (output-channel injection)	Partial	Output sanitization for syntactic exploits in downstream parsers is not addressed by any v1 control
AGT-009 (goal subversion via context manipulation)	Weak	Genuinely hard to address with technical controls alone; v1 controls provide only partial coverage
AGT-010 (resource exhaustion via agent loops)	Partial	Resource governance is implicit in CTL-003 but not explicit

These gaps are not implementation defects. They are design choices to keep v1 small and bounded. They are also the strongest candidates for v2 control work.

8.3 Reasoning provenance is fundamentally limited

CTL-005 captures audit and accountability across user attribution, agent attribution, context provenance, decision provenance, and authorization basis. One of these dimensions, model reasoning provenance, is fundamentally constrained by current LLM technology. Models do not produce reliable, deterministic explanations of their own decisions. Where models emit chain-of-thought, the audit can capture it. Where they do not, the audit cannot synthesize what was not produced.

This is a limit of the underlying technology, not a gap that v2 of this framework will close. Practitioners should treat agent decisions as partially opaque and design oversight assuming this constraint. For high-stakes decisions, human review at the action boundary is the only fully reliable accountability mechanism, which is why CTL-003 (action verification at high-impact boundaries) is the structural acknowledgment of this limit. Interpretability research may improve the situation in time, but the framework treats it as a constraint to design around rather than a gap to close.

8.4 The framework lacks documented incident examples

Each threat exemplar in section 5 includes a `realistic_example` field that is currently null. The framework is theoretically grounded in attack patterns and structural reasoning but does not yet illustrate threats with public incident data, anonymized customer scenarios, or documented breaches. This makes the framework less vivid for readers unfamiliar with agent security, and it makes the threats easier to dismiss as hypothetical even though the patterns are observed in research and in the field.

Populating realistic examples is a v2 priority. Sources will include public security research disclosures, anonymized scenarios from regulatory enforcement actions where available, and contributed examples from practitioner engagements where they can be sanitized for publication. Until v2, readers should treat the threat exemplars as well-grounded patterns awaiting evidentiary illustration in this specific document.

8.5 The vendor mapping interface is unproven

The framework is designed as a platform: vendor-specific control mappings are intended to be contributed by vendors and the community, not authored by the framework maintainer. The contribution interface is documented and the schema is defined, but no vendor mappings have been contributed as of v1 publication.

The platform model is unproven. Its value depends on adoption that has not yet happened. v2 evaluation will examine whether the contribution interface has produced meaningful mappings and what to adjust if not.

8.6 The framework does not address governance, culture, or organizational change

This framework is technical-practitioner-oriented. It addresses threats, controls, and regulatory mappings at the architectural and operational level. It does not address the organizational work of integrating AI security into procurement, shifting development culture, or building cross-functional governance. This is a deliberate scope choice. Most enterprise AI security failures will be governance failures as much as technical control failures, but addressing both in one document would dilute the focus and produce a less useful technical reference. Organizations should pair this framework with NIST AI RMF, ISO/IEC 42001, or ENISA AI cybersecurity guidance for the governance layer.

8.7 v1.1 commitments

The following items were intentionally deferred from v1 to keep the framework scope bounded and publishable. They are recorded here as commitments for the v1.1 release rather than v2, because they extend existing v1 content to parity rather than introducing new control or threat work.

Commitment	What it covers	Why deferred from v1
Populate AGT-003 through AGT-010 to parity with AGT-001 and AGT-002	Add attack scenario depth, traditional controls and why insufficient, full residual-risk analysis, detection and mitigation maturity, and realistic deployment examples for the eight compressed exemplars in Section 5	Time-bounded curation; the compressed form is sufficient for pattern recognition at v1, but practitioners using the framework for engagement-grade threat modeling need the deeper form
Merge full exemplar bodies into the canonical document	The canonical document at v1 contains the Section 5 framing only; exemplar bodies live in <code>docs/sections/05-threat-model.md</code> . v1.1 will inline the full bodies in the canonical document so the single-file artifact is self-contained	Avoided duplication while exemplar depth was uneven; defer to when AGT-003 through AGT-010 reach parity
Annex B (worked example)	A concrete deployment scenario walked through the threat model, the five v1 controls, and the regulatory crosswalk; intended to make the framework vivid for readers unfamiliar with agent security	The worked example requires a specific deployment context the framework does not yet have a sanitized example for; deferred rather than fabricated

These commitments are bounded extensions of existing v1 content. They are distinct from v2 work, which extends the control library and expands the framework scope.

What v2 will address

The gaps above produce a v2 control library priority list:

Priority	Addresses
Memory and persistence provenance control	AGT-006 coverage gap
Runtime resource governance control	AGT-010 coverage gap
Output sanitization control or refinement	AGT-008 coverage gap
CTL-003 refinement for composed actions	AGT-003 coverage gap

Beyond the control library, v2 will also populate realistic examples for the threat exemplars, evaluate the vendor mapping platform, and consider whether the methodology section needs strengthening for goal subversion (AGT-009), which remains the threat with the weakest v1 coverage.

v1 is bounded honestly to what it can defend. The framework is more useful for being explicit about that boundary than for pretending coverage it does not have.

9. References

How references are organized

This section consolidates the sources cited throughout the practitioner guide. It is a working reference list, not an academic bibliography. Entries are short-form (title, publisher, identifier or URL where applicable) and grouped by source type. Where a source is cited in multiple sections, it appears only once.

For verified dates, article references, and citation specifics for the four primary EU regulatory instruments, see also [../frameworks/regulatory-facts.md](#) in this repository, which is the source-of-truth reference file maintained alongside this guide.

EU regulations

Citation	Source
Regulation (EU) 2024/1689 of the European Parliament and of the Council laying down harmonised rules on artificial intelligence (Artificial Intelligence Act)	EUR-Lex, https://eur-lex.europa.eu/eli/reg/2024/1689/oj
Directive (EU) 2022/2555 of the European Parliament and of the Council on measures for a high common level of cybersecurity across the Union (NIS2 Directive)	EUR-Lex, https://eur-lex.europa.eu/eli/dir/2022/2555/oj
Regulation (EU) 2022/2554 of the European Parliament and of the Council on digital operational resilience for the financial sector (Digital Operational Resilience Act, DORA)	EUR-Lex, https://eur-lex.europa.eu/eli/reg/2022/2554/oj
Regulation (EU) 2016/679 of the European Parliament and of the Council on the protection of natural persons with regard to the processing of personal data (General Data Protection Regulation, GDPR)	EUR-Lex, https://eur-lex.europa.eu/eli/reg/2016/679/oj
Directive (EU) 2022/2556 (DORA Directive, companion to Regulation 2022/2554)	EUR-Lex, https://eur-lex.europa.eu/eli/dir/2022/2556/oj

EU institutional guidance

Citation	Source
European Commission, AI Act implementation guidance	digital-strategy.ec.europa.eu/en/policies/regulatory-framework-ai
AI Act Service Desk, Article-level guidance	ai-act-service-desk.ec.europa.eu
European Data Protection Board (EDPB), Guidelines on Automated Individual Decision-Making and Profiling, WP251rev.01	edpb.europa.eu
European Supervisory Authorities (EBA, EIOPA, ESMA), DORA Regulatory Technical Standards on ICT risk management, incident reporting, and third-party risk	esas-joint-committee.europa.eu
ESAs, Designated Critical ICT Third-Party Providers under DORA (first list, 18 November 2025)	Joint ESA publication
ENISA, NIS2 Directive guidance and sector taxonomies	enisa.europa.eu

National and sector-specific rules (DACH)

Citation	Source
BSI, Cloud Computing Compliance Criteria Catalogue (C5:2020 and C5:2026)	bsi.bund.de/EN/Themen/Unternehmen-und-Organisationen/Informationen-und-Empfehlungen/Empfehlungen-nach-Angriffszielen/Cloud-Computing/Kriterienkatalog-C5
C5-Gleichwertigkeitsverordnung (Verordnung über gleichwertige Sicherheitsnachweise zum C5-Standard für Cloud-Computing-Dienste im Gesundheitswesen), 19 March 2025, BGBl. 2025 I Nr. 91	gesetze-im-internet.de/c5gleichvv
§ 393 SGB V (Fünftes Buch Sozialgesetzbuch), introduced by the Digital-Gesetz (DigiG), 22 March 2024	gesetze-im-internet.de/sgb_5
BSI, IT-Grundschutz-Kompendium (current edition)	bsi.bund.de/DE/Themen/Unternehmen-und-Organisationen/Standards-und-Zertifizierung/IT-Grundschutz/IT-Grundschutz-Kompendium
BSI IT-Grundschutz, Baustein ORP.1 (Organisation), ORP.4 (Identitäts- und Berechtigungsmanagement), CON.2 (Datenschutz), CON.6 (Löschen und Vernichten), CON.10 (Entwicklung von Webanwendungen), DER.1 (Detektion), OPS.1.1.5 (Protokollierung), OPS.1.2.4 (Telearbeit)	BSI IT-Grundschutz-Kompendium
Germany NIS2 transposition (NIS2-Umsetzungs- und Cybersicherheitsstärkungsgesetz, NIS2UmsuCG), in force 6 December 2025	Bundesgesetzblatt 2025; bsi.bund.de

International standards and frameworks

Citation	Source
NIST SP 800-53 Rev. 5, Security and Privacy Controls for Information Systems and Organizations	nist.gov/publications
NIST SP 800-37 Rev. 2, Risk Management Framework for Information Systems and Organizations	nist.gov/publications
NIST SP 800-61 Rev. 2, Computer Security Incident Handling Guide	nist.gov/publications
NIST SP 800-92, Guide to Computer Security Log Management	nist.gov/publications
NIST SP 800-122, Guide to Protecting the Confidentiality of Personally Identifiable Information	nist.gov/publications
NIST SP 800-207, Zero Trust Architecture	nist.gov/publications
NIST SP 800-218, Secure Software Development Framework (SSDF)	nist.gov/publications
NIST AI 100-1, AI Risk Management Framework (AI RMF 1.0)	nist.gov/itl/ai-risk-management-framework
NIST AI 100-2 E2025, Adversarial Machine Learning: A Taxonomy and Terminology of Attacks and Mitigations	nist.gov/publications
ISO/IEC 27001:2022, Information security, cybersecurity and privacy protection, Information security management systems, Requirements	iso.org
ISO/IEC 27018:2019, Code of practice for protection of personally identifiable information in public clouds acting as PII processors	iso.org
ISO/IEC 27037:2012, Guidelines for identification, collection, acquisition and preservation of digital evidence	iso.org
ISO/IEC 38500:2024, Governance of information technology	iso.org
ISO/IEC 42001:2023, Information technology, Artificial intelligence, Management system	iso.org
ISO 22301:2019, Security and resilience, Business continuity management systems	iso.org
MITRE ATLAS (Adversarial Threat Landscape for Artificial-Intelligence Systems), Matrix v5.4.0	atlas.mitre.org
OWASP Top 10 for Large Language Model Applications	owasp.org/www-project-top-10-for-large-language-model-applications

IETF and protocol specifications

Citation	Source
RFC 6749, The OAuth 2.0 Authorization Framework	datatracker.ietf.org/doc/html/rfc6749
RFC 8693, OAuth 2.0 Token Exchange	datatracker.ietf.org/doc/html/rfc8693
RFC 9068, JSON Web Token (JWT) Profile for OAuth 2.0 Access Tokens	datatracker.ietf.org/doc/html/rfc9068
RFC 9421, HTTP Message Signatures	datatracker.ietf.org/doc/html/rfc9421
SPIFFE (Secure Production Identity Framework For Everyone) and SPIRE specifications	spiffe.io

Academic and practitioner sources

Citation	Source
Greshake, K., et al., "Not What You've Signed Up For: Compromising Real-World LLM-Integrated Applications with Indirect Prompt Injection," Proceedings of the 16th ACM Workshop on Artificial Intelligence and Security (AISeC '23), 2023	dl.acm.org or arxiv.org/abs/2302.12173
AI Safety Institute (UK AISI) and partners, evaluation guidance for foundation models	aisi.gov.uk

Repository internal references

Item	Path
Project brief	<code>PROJECT_BRIEF.md</code>
Threat model framework	<code>docs/frameworks/THREAT_MODEL_FRAMEWORK.md</code>
Control library framework	<code>docs/frameworks/CONTROL_LIBRARY_FRAMEWORK.md</code>
Regulatory facts (source of truth for dates and article references)	<code>docs/frameworks/regulatory-facts.md</code>
Threat catalog (data)	<code>data/threats.json</code>
Control library (data)	<code>data/controls.json</code>
Bidirectional mappings	<code>data/mappings.json</code>

Notes on currency and verification

Regulatory citations were verified against EUR-Lex and Commission sources in May 2026. Specific application dates, transposition status, and Article references are subject to change as member-state implementation progresses and as the Digital Omnibus simplification proposal (published 19 November 2025) advances. For the current state of these items, consult `../frameworks/regulatory-facts.md`, which is updated as part of repository maintenance, and verify directly against EUR-Lex and the relevant national supervisory authority before relying on any citation here for compliance decisions.

Threat-specific citations in `data/threats.json` include placeholders ("Recent work on indirect prompt injection from 2024 to 2026 (specific citations to be selected during section drafting)" and similar). These placeholders persist into v1 and will be filled during the v2 expansion of the threat catalog. They are noted

here for transparency rather than included as references.

Appendix A. ServiceNow Mapping (Optional)

Placeholder.